

INFORME DE RECONOCIMIENTO

Recopilación de información sobre el programa
HackerOne (scope: *.hilton.com)

Cliente: KeepCoding Tech School

Auditor: Michelli Melo

Fecha: Marzo 2026

Versión: 1.0

Clasificación: **CONFIDENCIAL**

Índice

[Índice](#)

[1. Introducción](#)

[Objetivo del trabajo](#)

[Organización objetivo \(Hilton\)](#)

[Programa y justificación de selección del objetivo](#)

[2. Alcance y reglas del programa \(HackerOne\)](#)

[Programa seleccionado \(HackerOne\)](#)

[Activos in scope \(selección del objetivo\)](#)

[Exclusiones explícitas \(out of scope\) aplicadas a este trabajo](#)

[Reglas de test y límites operativos \(criterio de cumplimiento\)](#)

[Evidencia y trazabilidad para reproducibilidad](#)

[3. Metodología de trabajo](#)

[Flujo completo aplicado](#)

[Gestión de outputs y anexos \(estructura de ficheros\)](#)

[Sistema y contexto de ejecución \(Kali\)](#)

[Instalación y estructura de trabajo](#)

[Herramientas utilizadas \(resumen\)](#)

[5. Footprinting](#)

[Dominio wildcard seleccionado](#)

[Reglas aplicadas de in/out \(criterio de filtrado\)](#)

[Preparación de listas y wordlists \(si aplica\)](#)

[DNS Bruteforce \(shuffledns\)](#)

[Objetivo del paso](#)

[Inputs utilizados](#)

[Ejecución \(comando\)](#)

[Normalización y depuración del output](#)

[Interpretación del resultado](#)

[Evidencia:](#)

[Anexos generados:](#)

[Reconocimiento vertical \(enumeración de subdominios\)](#)

[Google Analytics \(analyticsrelationships\) — Versión final](#)

[Objetivo del paso](#)

[Herramienta empleada](#)

[Ejecución \(comandos exactos utilizados\)](#)

[Resultado obtenido](#)

[Control de calidad \(QC\)](#)

[Evidencia \(captura\)](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[TLS Probing \(cero\)](#)

[Objetivo del paso](#)

[Input utilizado](#)

[Validación de verticalidad y filtrado por dominio objetivo](#)

[Control de calidad \(QC\)](#)

[Evidencia \(captura\)](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[Web scraping / crawling \(katana\)](#)

[Objetivo del paso](#)

[Herramienta empleada](#)

[Ejecución \(comando exacto utilizado\)](#)

[Normalización y depuración del output](#)

[Control de calidad \(QC\)](#)

[Evidencia](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[Certificate Transparency logs \(ctfr\)](#)

[Objetivo del paso](#)

[Herramienta empleada](#)

[Ejecución \(comando exacto utilizado\)](#)

[Normalización y depuración del output](#)

[Resultado obtenido](#)

[Control de calidad \(QC\)](#)

[Evidencia \(captura\)](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[Archivos web y caché \(gau\)](#)

[Objetivo del paso](#)

[Herramienta empleada](#)

[Ejecución \(comando exacto utilizado\)](#)

[Resultado obtenido](#)

[Normalización y depuración del output](#)

[Control de calidad \(QC\)](#)

[Nota metodológica](#)

[Evidencia \(captura\)](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[6. Fingerprint](#)

[Validar subdominios vivos/online \(httpx\)](#)

[Objetivo del paso](#)

[Input utilizado](#)

[Ejecución \(comando exacto utilizado\)](#)

[Limpieza para lista de hosts \(eliminar http/https\)](#)

[Control de calidad \(QC\)](#)

[Evidencia \(captura\)](#)

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[Escaneo de puertos — Masscan / Nmap](#)

[Masscan](#)

[Input y preparación previa \(dominios → IPs\)](#)

[Ejecución \(comando exacto utilizado\)](#)

[Resultado obtenido \(puertos detectados\)](#)

[Preparación de subset para verificación \(targets no web\)](#)

[Control de calidad \(QC\)](#)

Evidencia

Anexos generados (para el ZIP de outputs CLI)

Nmap

Objetivo del paso

Input utilizado

Ejecución (comando exacto utilizado)

Resultado obtenido (resumen)

Hallazgos representativos

Control de calidad (QC)

Evidencia (captura)

Anexos generados (para ZIP de outputs CLI)

Análisis visual y tecnología web (GoWitness)

Objetivo del paso

Input utilizado

Ejecución (comando exacto utilizado)

Exportación a la carpeta de trabajo (evidencia y trazabilidad)

Visualización del reporte

Control de calidad (QC)

Evidencia

Anexos generados (para ZIP de outputs/evidencias)

6.4 Detección de WAFs (wafw00f)

Objetivo del paso

Input utilizado

Ejecución (comando exacto utilizado)

Resultado obtenido (interpretación)

Control de calidad (QC)

Evidencia (captura)

Descubrimiento de contenido (ffuf)

Objetivo

Herramienta y criterios

Ejecución realizada (comandos y decisiones)

Evidencias y anexos generados

Conclusión

Anexos generados (para ZIP de outputs CLI)

7. Analisis de vulnerabilidades

7.1 Análisis de vulnerabilidades web (Nuclei) — ejecución parcial por limitación de tiempo

7.2 Comprobar subdomain takeover (subzy sobre lista de subdominios)

Objetivo del paso

Input utilizado

Instalación (Go) y disponibilidad de la herramienta

Ejecución (comando exacto utilizado)

Resultado obtenido (candidatos señalados por subzy)

Validación mínima (DNS y HTTP) de los candidatos

Control de calidad (QC)

Evidencia

[Anexos generados \(para el ZIP de outputs CLI\)](#)

[7.3 Análisis SSL/TLS — SSL Labs \(dominio principal\)](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados \(datos relevantes del informe\)](#)

[Interpretación \(para el informe\)](#)

[Evidencia](#)

[Anexos generados](#)

[7.4 Análisis DMARC/SPF/DKIM — dmarcian domain checker \(dominio principal\)](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados obtenidos \(según dmarcian\)](#)

[1\) DMARC](#)

[2\) SPF](#)

[3\) DKIM](#)

[Interpretación global \(riesgo y postura\)](#)

[Evidencia: \(capturas zqui\)](#)

[Anexos generados](#)

[8. OSINT](#)

[8.1 Identificación inicial de empleados relevantes y análisis de presencia en redes mediante Sherlock](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados obtenidos](#)

[Interpretación técnica](#)

[Interpretación global](#)

[Evidencia](#)

[Anexos generados](#)

[8.2 Localización de emails de empleados, empleados relevantes y comprobación de data breaches](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados obtenidos](#)

[Interpretación técnica](#)

[Interpretación global](#)

[Evidencia](#)

[Anexos generados](#)

[8.3 Extracción de metadatos](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados obtenidos](#)

[Interpretación técnica](#)

[Interpretación global](#)

[Evidencia](#)

[Anexos generados](#)

[8.4 Análisis de redes sociales — comprobación de username con WhatsMyName y limitación operativa en CheckUser](#)

[Objetivo del paso](#)

[Ejecución](#)

[Resultados obtenidos](#)

[Interpretación técnica](#)

[Interpretación global](#)

[Evidencia](#)

[Anexos generados](#)

[Conclusión](#)

1. Introducción

Objetivo del trabajo

El objetivo de este trabajo es realizar una **recopilación de información (reconocimiento)** sobre una organización real, siguiendo un enfoque metódico y reproducible, con el fin de **identificar activos expuestos**, construir una **lista de objetivos validada** (dominios, subdominios e IPs) y, a partir de ella, ejecutar tareas de **fingerprinting, análisis de vulnerabilidades y OSINT**, siempre dentro de los límites definidos por el programa.

El resultado final se materializa en un **informe de inteligencia** orientado a evidenciar la superficie de ataque y a localizar posibles **malas configuraciones, exposición innecesaria o información sensible**, sin realizar explotación ni acciones fuera de alcance.

Organización objetivo (Hilton)

La organización seleccionada para esta práctica es **Hilton**, una compañía internacional del sector hotelero con presencia global y una huella digital amplia (infraestructura web, aplicaciones y servicios asociados a diferentes dominios corporativos).

Por la naturaleza del negocio y su escala, Hilton opera múltiples plataformas orientadas a la gestión de reservas, programas de fidelización, servicios a clientes y portales corporativos, lo que convierte su ecosistema digital en un objetivo adecuado para una práctica de reconocimiento vertical, ya que permite observar diversidad tecnológica, subdominios y superficies web de interés para análisis posteriores.

Programa y justificación de selección del objetivo

La práctica se realiza bajo el marco del **programa de Bug Bounty en HackerOne** correspondiente a Hilton. Esto garantiza que el reconocimiento se ejecuta bajo un **scope explícito**, con reglas claras de lo permitido y lo excluido, y permite justificar técnicamente (y de forma verificable) por qué los activos analizados son válidos para el trabajo.

Dentro de dicho programa, se ha escogido como objetivo principal el wildcard ***.hilton.com**, al tratarse del dominio corporativo con mayor cobertura y potencial de enumeración de subdominios, lo que favorece encontrar más superficie de análisis, tal y como requiere el enfoque de reconocimiento vertical explicados en clase.

2. Alcance y reglas del programa (HackerOne)

Programa seleccionado (HackerOne)

El reconocimiento se ejecuta bajo el programa público de Hilton en HackerOne. Este programa define los activos permitidos (in scope), las exclusiones (out of scope) y las condiciones operativas del testing. El informe se centra exclusivamente en activos listados como **in scope** y aplica las exclusiones indicadas en el propio scope.

Activos in scope (selección del objetivo)

Para esta práctica se selecciona el activo **Wildcard *.hilton.com** marcado como **In scope**, al ser un dominio con cobertura amplia y adecuada para reconocimiento vertical. La elección del wildcard permite enumerar subdominios y construir una lista amplia de objetivos, que posteriormente se validará, filtrará y priorizará antes de pasar a fingerprinting y análisis de vulnerabilidades.

The screenshot shows the HackerOne interface for the Hilton bug bounty program. At the top, there are filters for Search, Scope (In scope), Maximum severity (Any), and Bounty eligibility (All). Below the filters, there are links to download configuration files and view changes. The main table lists assets with columns for Asset name, Type, Coverage, Max. severity, Bounty, Last update, and Resolved Reports. The asset *.hilton.com is highlighted with a red box. To the right, there is a sidebar with the Hilton logo, a link to the program page, and a section for rewards.

Asset name	Type	Coverage	Max. severity	Bounty	Last update	Resolved Reports
121.200.237.36/29	CIDR	In scope	Critical	Eligible	Mar 21, 2023	0 (0%)
*.hiltonlocalbiz.com	Wildcard	In scope	Critical	Eligible	Jul 27, 2023	0 (0%)
*.hiltonbusinessonline.com	Wildcard	In scope	Critical	Eligible	May 15, 2023	2 (0%)
*.hilton.io	Wildcard	In scope	Critical	Eligible	May 15, 2023	2 (0%)
*.hilton.com All subdomains of hilton.com that resolve to IP addresses belonging to the Rackspace organization are considered out of scope. In addition, the application eis.hilton.com is out of scope.	Wildcard	In scope	Critical	Eligible	May 15, 2023	153 (35%)

Exclusiones explícitas (out of scope) aplicadas a este trabajo

Aunque el wildcard ***.hilton.com** está en scope, el programa incorpora exclusiones que deben aplicarse desde el inicio para evitar trabajar sobre activos no permitidos. En particular, se aplican las siguientes restricciones operativas:

- **Exclusión por infraestructura (Rackspace):** todos los subdominios de **hilton.com** que resuelvan a direcciones IP pertenecientes a la organización Rackspace deben considerarse **out of scope**.
- **Exclusión específica de aplicación:** la aplicación **es.hilton.com** se considera **out of scope**.

Estas exclusiones condicionan la fase de validación de objetivos: cualquier host detectado durante el reconocimiento vertical que cumpla alguno de esos criterios se separará inmediatamente en una lista OUT (no objetivo) y no se continuará con fingerprinting ni escaneos sobre él.

Reglas de test y límites operativos (criterio de cumplimiento)

Todo el trabajo se ejecuta bajo el principio de **mínima intrusión** y estricta alineación con el scope. En consecuencia:

- El reconocimiento prioriza técnicas pasivas y activas “suaves” orientadas a enumeración y validación (resolución DNS, disponibilidad HTTP/HTTPS, identificación tecnológica).
- No se realizan pruebas que impliquen denegación de servicio, fuerza bruta agresiva o cualquier actividad no contemplada en el programa.
- Cualquier hallazgo o activo detectado se documenta con trazabilidad (comando, fecha, herramienta y output), y se valida contra el scope antes de considerarlo objetivo.

Evidencia y trazabilidad para reproducibilidad

Siguiendo lo exigido por la práctica, cada fase del trabajo generará evidencias verificables:

- comandos ejecutados,
- outputs guardados como anexos,
- listas intermedias (raw/merged/validated),
- y la lista final de objetivos “IN scope” depurada.

Esto permite que un tercero pueda replicar el proceso paso a paso y comprobar que los resultados se obtuvieron conforme al scope del programa.

3. Metodología de trabajo

Flujo completo aplicado

Este trabajo sigue de forma estricta el flujo metodológico indicado por el profesor para la práctica de Recopilación de Información.

En primer lugar se parte del **scope oficial** del programa (HackerOne), que define los activos permitidos y las exclusiones.

A continuación se ejecuta un **reconocimiento vertical** del dominio objetivo para enumerar subdominios por múltiples fuentes y técnicas.

Con los resultados se realiza una fase de **comprobación de validez**, donde se depuran duplicados, se valida resolución DNS/HTTP y se aplican filtros de exclusión derivados del scope (por ejemplo, activos expresamente out-of-scope).

Una vez validado el conjunto de activos, se construye una **lista final de objetivos (targets)** que alimenta las fases posteriores.

Sobre esa lista se ejecuta el **Fingerprinting**, con el propósito de identificar tecnologías, servicios expuestos, WAF, y superficies web relevantes.

Después se realiza el **análisis de vulnerabilidades** mediante escaneo automatizado y comprobaciones técnicas acotadas, sin explotación, y finalmente se completa el trabajo con **OSINT y redes sociales**, orientado a localizar información pública potencialmente sensible (documentos, metadatos, filtraciones, exposición de emails/usuarios, etc.).

El informe concluye consolidando hallazgos y elaborando un **informe de inteligencia**: superficie, evidencias, y riesgos prioritarios.

Flujo aplicado:

Scope HackerOne → Reconocimiento vertical → Comprobación de validez → Lista de objetivos → Fingerprinting + Análisis de vulnerabilidades + OSINT → Hallazgos → Informe de inteligencia.

Gestión de outputs y anexos (estructura de ficheros)

Para garantizar trazabilidad y reproducibilidad, cada herramienta utilizada genera un output propio que se guarda como anexo. Adicionalmente se generan ficheros “consolidados” (listas depuradas) que actúan como entrada de la fase siguiente. Cada output se conserva con un nombre descriptivo, y cuando procede se mantiene el mismo criterio:

- **raw** (salida directa de herramienta)
- **clean** (normalización: minúsculas, dedupe, limpieza)
- **validated** (filtrado por scope / resolución / vivo)
- **final targets** (lista definitiva IN-scope)

Esta gestión permite replicar el proceso paso a paso, auditar decisiones (por qué se excluyó algo) y adjuntar evidencias completas sin sobrecargar el cuerpo principal del informe.

4. Preparación del entorno y tooling

Sistema y contexto de ejecución (Kali)

Toda la práctica se ejecuta desde un entorno Linux (Kali), utilizando herramientas estándar del ecosistema de reconocimiento y ProjectDiscovery. La ejecución se realiza con criterios de control (tasa y volumen razonables) para minimizar impacto y mantener el trabajo dentro del marco permitido por el programa.

Instalación y estructura de trabajo

La preparación del entorno se realiza mediante el script `tools.sh`, que instala y configura el conjunto de utilidades requeridas por el módulo. Este script crea la estructura base de directorios:

- `$HOME/recopilacion` como carpeta raíz del proyecto.
- `$HOME/recopilacion/lists` para listas auxiliares (wordlists, resolvers, inputs).

A partir de esa base, para el objetivo `hilton.com` se crea una estructura por fases (Footprinting, Fingerprinting, Vulnerabilidades, OSINT) donde se guardan outputs y ficheros consolidados por herramienta.

Herramientas utilizadas (resumen)

La práctica utiliza las herramientas indicadas para cada fase, entre ellas:

- **Footprinting vertical:** `shuffledns`, `analyticsrelationships`, `katana`, `ctfr`, `gau` (y validación con `resolvalid/dnsx` si procede).
- **Fingerprinting:** `httpx`, `nmap` o `masscan`, `gowitness`, `whatweb`, `wafw00f`, `ffuf`.
- **Análisis de vulnerabilidades:** `nuclei`, `subzy`, comprobación TLS con **SSL Labs** (dominio principal), y verificación de correo con **DMARCian**.
- **OSINT + redes sociales:** búsqueda de emails/empleados + **HIBP**, metadatos manual o con `exifray`.

5. Footprinting

Dominio wildcard seleccionado

El objetivo seleccionado para el reconocimiento vertical es el dominio corporativo `hilton.com`, trabajando bajo el activo wildcard `*.hilton.com` definido como **In scope** en el programa de HackerOne correspondiente a la organización. La elección de un wildcard permite enumerar subdominios de forma amplia y coherente con la metodología del profesor, construyendo una superficie inicial de activos que posteriormente se validará, depurará y priorizará para las fases de fingerprinting, análisis de vulnerabilidades y OSINT.

Reglas aplicadas de in/out (criterio de filtrado)

Todo el trabajo se ejecuta bajo el principio de **alineación estricta con el scope** del programa. Por tanto, el criterio operativo aplicado en este informe es:

- **In scope operativo:** subdominios del tipo `*.hilton.com` que cumplan las condiciones del programa y no estén explícitamente excluidos.
- **Out of scope operativo:** cualquier activo que el programa excluya de forma explícita o condicional. En particular, se aplica la exclusión específica de `es.hilton.com` (out of scope) y la exclusión

condicional indicada por el programa: **subdominios de hilton.com que resuelvan a direcciones IP pertenecientes a Rackspace** se consideran **out of scope**.

Para mantener trazabilidad y evitar errores, este filtrado se aplica de forma verificable en la fase de validación/targets (cuando se resuelve a IP y se puede justificar la clasificación). Durante la enumeración (5.x) se conserva evidencia “raw” por técnica y la clasificación IN/OUT se formaliza al construir la lista final de objetivos.

Preparación de listas y wordlists (si aplica)

Siguiendo la guía del curso, se prepara el entorno de trabajo en Kali y se utilizan listas estándar instaladas mediante el script del módulo. En particular:

- **Wordlist para DNS bruteforce (shuffledns):** se utiliza la wordlist del profesor ubicada en `~/recopilacion/lists/domains.txt`, descargada por `tools.sh` desde SecLists (subdomains-top1million-5000), con un tamaño verificado de **5000** entradas.
- **Resolvers DNS validados:** se utiliza el fichero `~/recopilacion/lists/resolvers.txt` (conjunto de resolvers funcionales) para mejorar la fiabilidad de resolución durante la enumeración y reducir falsos negativos.

Estas listas se emplean como inputs directos en las técnicas de reconocimiento vertical, y sus tamaños se registran como control de calidad en cada paso donde se utilicen

DNS Bruteforce (shuffledns)

Objetivo del paso

En reconocimiento vertical, el objetivo de esta fase es **descubrir subdominios existentes** bajo el dominio raíz `hilton.com` mediante **fuerza bruta DNS**. La lógica es simple: si probamos una lista controlada de prefijos comunes (por ejemplo `www`, `api`, `mail`, `vpn`, `dev`, etc.) y preguntamos a resolvers DNS válidos, obtendremos aquellos nombres que **realmente resuelven** y, por tanto, son candidatos a objetivo para las fases siguientes (validación, fingerprinting y análisis de exposición).

Este método complementa otras fuentes (CT logs, crawling, archivos históricos) porque encuentra subdominios que pueden no aparecer en certificados ni en URLs públicas, pero que sí existen en DNS.

Inputs utilizados

Para ejecutar el brute force DNS hacen falta dos entradas:

1. **Lista de resolvers DNS funcionales (`resolvers.txt`)**
Se utiliza para evitar falsos negativos (resolución fallida por DNS caídos) y mejorar la estabilidad del proceso. En tu caso ya existía y se reutilizó:

`~/recopilacion/lists/resolvers.txt` (166 entradas)

2. Wordlist (`domains.txt`)

El profesor define explícitamente el uso de la wordlist descargada por `tools.sh` en:

`~/recopilacion/lists/domains.txt`

Esta lista contiene **5000** candidatos (prefijos) y se usa como base estándar para el brute force.

Ejecución (comando)

Se ejecuta `shuffledns` en modo bruteforce, indicando dominio, wordlist y resolvers. Se usa `-silent` para obtener salida limpia y se redirige a fichero para anexos:

- Dominio objetivo: `hilton.com`
- Modo: `bruteforce`
- Wordlist: `~/recopilacion/lists/domains.txt`
- Resolvers: `~/recopilacion/lists/resolvers.txt`
- Output: `~/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt`

Resultado: se generó un fichero con **128** subdominios detectados.

Normalización y depuración del output

Para que el resultado sea reproducible y usable en los siguientes pasos, se generó un fichero “clean” aplicando:

- minúsculas (normalización),
- eliminación de retornos `\r` (si existen),
- ordenación y deduplicación.

Artefacto final:

`~/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt` (**128** líneas)

Interpretación del resultado

Los valores obtenidos (p. ej. `www.jobs.hilton.com`, `www.my.hilton.com`, etc.) son **subdominios de hilton.com**, por tanto pertenecen al **reconocimiento vertical**. En esta fase todavía **no** se aplica el filtrado

por exclusiones de infraestructura (Rackspace) porque ese criterio requiere resolución a IP y se realiza en la fase de **validación/targets**. En esta etapa el objetivo es enumerar, no excluir.

Evidencia:

```
(kali@kali)-[~]
$ ls -la "$HOME/recopilacion/lists/domains.txt"
-rw-rw-r-- 1 kali kali 30075 Feb 25 06:21 /home/kali/recopilacion/lists/domains.txt

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/lists/domains.txt"
5000 /home/kali/recopilacion/lists/domains.txt

(kali@kali)-[~]
$ shuffledns -mode bruteforce -d hilton.com -w "$HOME/recopilacion/lists/domains.txt" -r "$HOME/recopilacion/lists/resol
vers.txt" -silent > "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt"

(kali@kali)-[~]
$

(kali@kali)-[~]
$ ls -la "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt" 66 wc -l "$HOME/recopilacion/hilton.com/05_f
ootprinting/shuffledns_raw.txt" 66 head -n 5 "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt"
-rw-rw-r-- 1 kali kali 2209 Mar 4 06:22 /home/kali/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt
128 /home/kali/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt
wss.hilton.com
webapps.hilton.com
gis.hilton.com
post.hilton.com
cms.hilton.com

(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_raw.txt" \
| tr '[:upper:]' '[:lower:]' \
| sed 's/\r$//' \
| sort -u \
> "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt" 66 tail -n 5 "$HOME/recopilacion/hilton.com
/05_footprinting/shuffledns_clean.txt"
128 /home/kali/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt
www.jobs.hilton.com
www.my.hilton.com
www.test.hilton.com
www.travel.hilton.com
youth.hilton.com
```

Anexos generados:

- 05_footprinting/shuffledns_raw.txt
- 05_footprinting/shuffledns_clean.txt

Reconocimiento vertical (enumeración de subdominios)

Google Analytics (analyticsrelationships) — Versión final

Objetivo del paso

El objetivo de esta fase es identificar **relaciones entre dominios/subdominios** a partir de **identificadores compartidos de analítica** (por ejemplo, Google Tag Manager o Google Analytics). La hipótesis de trabajo es que, si varios activos del objetivo comparten el mismo identificador de tracking, pueden pertenecer al mismo ecosistema y revelar **nuevos dominios o subdominios** que no aparecen mediante DNS bruteforce, CT logs o crawling.

Herramienta empleada

Se utiliza `analyticsrelationships`, para analizar el dominio objetivo e intentar detectar artefactos de analítica (especialmente Tag Manager) que permitan derivar relaciones.

Ejecución (comandos exactos utilizados)

Se ejecutaron pruebas directas contra el dominio principal en los formatos habituales de la herramienta, guardando el output en fichero para anexos:

- `analyticsrelationships -u hilton.com > ../analyticsrelationships_raw.txt`
- `analyticsrelationships -u www.hilton.com > ../analyticsrelationships_raw.txt`
- `analyticsrelationships --url https://www.hilton.com/ > ../analyticsrelationships_raw.txt`

Output objetivo (anexo):

`~/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt`

Resultado obtenido

La herramienta analizó el objetivo pero **no detectó Tag Manager** (mensaje equivalente a “Tagmanager URL not found”), por lo que **no fue posible extraer IDs de tracking** ni derivar relaciones. En consecuencia, el fichero de salida quedó **vacío (0 líneas)**.

Este resultado es consistente con escenarios comunes en grandes organizaciones donde:

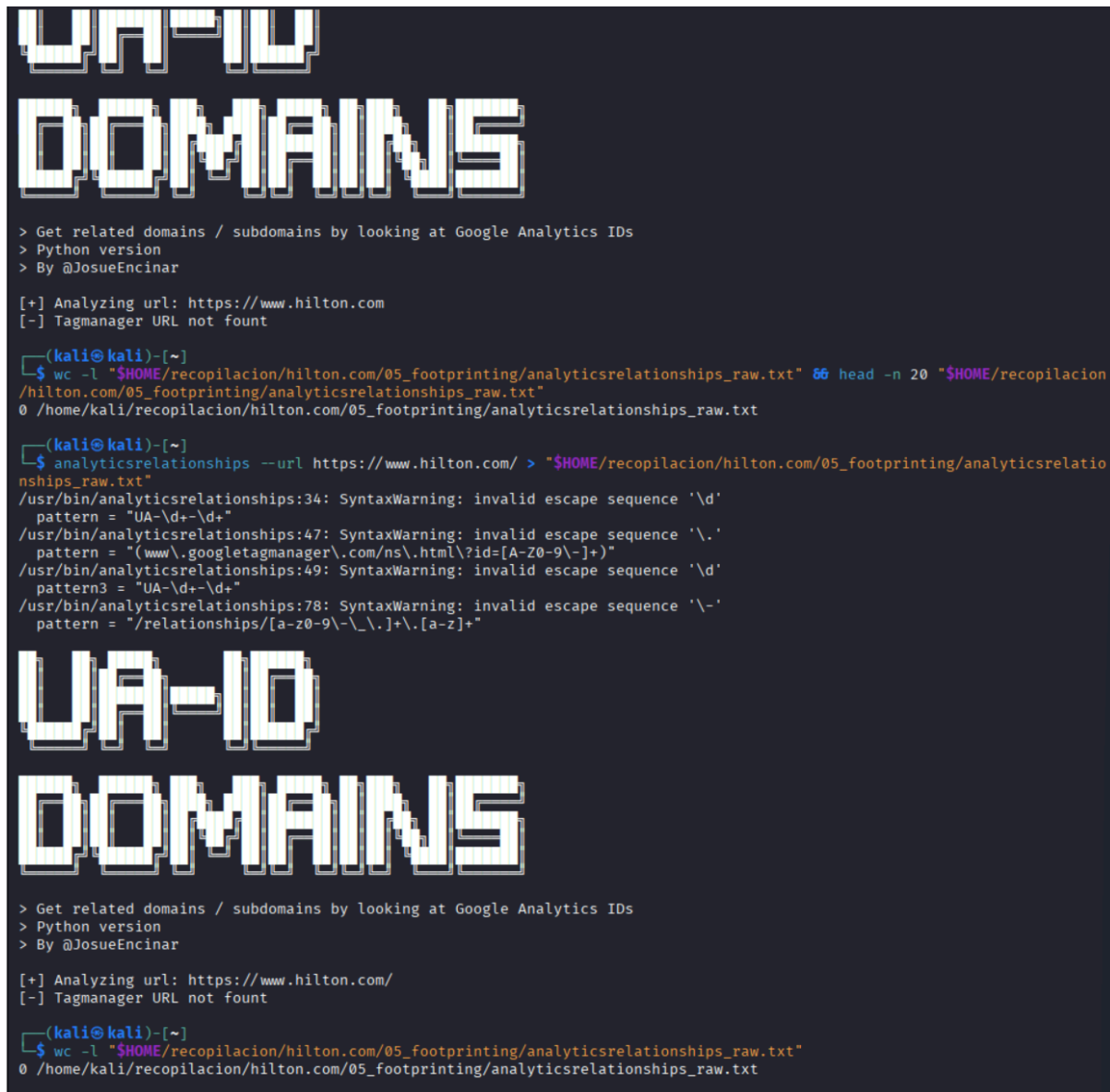
- la analítica se carga tras consentimiento (CMP) o de forma dinámica,

- se utiliza analítica server-side o proveedores alternativos,
- o existen mecanismos anti-bot / restricciones que impiden a la herramienta observar los scripts de tracking.

Control de calidad (QC)

- Fichero generado: **analyticsrelationships_raw.txt**
- Tamaño: **0 líneas** (sin hallazgos con esta técnica en el dominio probado).
- Decisión: continuar el reconocimiento vertical con el resto de fuentes del flujo (TLS probing, katana, ctfr, gau), que no dependen de la presencia de Tag Manager.

Evidencia (captura)



```

UA-ID
DOMAINS

> Get related domains / subdomains by looking at Google Analytics IDs
> Python version
> By @JosueEncinar

[+] Analyzing url: https://www.hilton.com
[-] Tagmanager URL not found

(kali@kali)~$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt" 66 head -n 20 "$HOME/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt"
0 /home/kali/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt

(kali@kali)~$ analyticsrelationships --url https://www.hilton.com/ > "$HOME/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt"
/usr/bin/analyticsrelationships:34: SyntaxWarning: invalid escape sequence '\d'
pattern = "UA-\d+-\d+"
/usr/bin/analyticsrelationships:47: SyntaxWarning: invalid escape sequence '\.'
pattern = "(www\.\googletagmanager\.com/ns\.html?id=[A-Z0-9\-\_]+)"
/usr/bin/analyticsrelationships:49: SyntaxWarning: invalid escape sequence '\d'
pattern3 = "UA-\d+-\d+"
/usr/bin/analyticsrelationships:78: SyntaxWarning: invalid escape sequence '\-'
pattern = "/relationships/[a-z0-9\-\_\.\_]+\.[a-z]+"

UA-ID
DOMAINS

> Get related domains / subdomains by looking at Google Analytics IDs
> Python version
> By @JosueEncinar

[+] Analyzing url: https://www.hilton.com/
[-] Tagmanager URL not found

(kali@kali)~$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt"
0 /home/kali/recopilacion/hilton.com/05_footprinting/analyticsrelationships_raw.txt

```

Anexos generados (para el ZIP de outputs CLI)

- `05_footprinting/analyticsrelationships_raw.txt` (vacío, se incluye para trazabilidad)

TLS Probing (cero)

Objetivo del paso

El objetivo del TLS probing es identificar dominios que **presentan servicios TLS accesibles** (por defecto en 443) y, a partir de esa información, descubrir **nombres de dominio adicionales** que puedan aparecer en el contexto de TLS (por ejemplo, por coincidencias/certificados/infraestructura). Esta técnica complementa el DNS bruteforce porque puede revelar activos que no han sido enumerados por diccionario, pero que están relacionados operativamente con el ecosistema analizado.

En esta práctica, además, se aplica el principio de reconocimiento vertical: el foco es `*.hilton.com`, por lo que cualquier dominio externo detectado se conserva como evidencia en el output raw pero **no** se incorpora como objetivo del vertical de `hilton.com` en esta fase.

Input utilizado

Se utilizó como entrada la lista depurada obtenida en el paso 5.1 (DNS bruteforce):

- `~/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt` (128 entradas)

Ejecución (comando exacto utilizado)

Se ejecutó `cero` con la opción `-d` para devolver únicamente nombres de dominio válidos, leyendo desde stdin y guardando la salida como anexo:

- Output generado:
 - `~/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt`

Resultado obtenido: **236** líneas.

Validación de verticalidad y filtrado por dominio objetivo

El output raw incluyó dominios ajenos a `hilton.com` (por ejemplo, dominios de terceros o de infraestructura). Para mantener el reconocimiento **vertical del dominio objetivo**, se generó un fichero filtrado que conserva únicamente `*.hilton.com`:

- Output filtrado (vertical):

- ~/recopilacion/hilton.com/05_footprinting/cero_tls_hilton_com.txt

Resultado filtrado: **68** entradas.

Este filtrado no aplica todavía exclusiones específicas del scope por proveedor (p. ej. Rackspace), ya que esa clasificación se realizará más adelante durante la fase de validación y construcción de la lista final de objetivos.

Control de calidad (QC)

- Input: `shuffledns_clean.txt` (128)
- Output raw: `cero_tls_raw.txt` (236)
- Output vertical (*.hilton.com): `cero_tls_hilton_com.txt` (68)
- Decisión metodológica: conservar raw como evidencia y usar el filtrado `*.hilton.com` como resultado operativo de esta técnica dentro del reconocimiento vertical.

Evidencia (captura)

```
(kali@kali)-[~]
$ cero -d < "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt" > "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt" 86 head -n 10 "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt"
236 /home/kali/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt
jobs.hilton.com
ir.hilton.com
learn.hilton.com
p.hilton.com
apim.p.hilton.io
developer.hilton.io
developer.hiltonapi.com
fd.hilton.com
id.hilton.com
images.hiltonstatic.com

(kali@kali)-[~]
$ comm -13 <(sort "$HOME/recopilacion/hilton.com/05_footprinting/shuffledns_clean.txt") <(sort "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt") | head
3.hilton.com
aadcdnimages.privatelink.msidentity.com
aadcdnimages.privatelink.msidentity.com
aadcdn.privatelink.msidentity.com
aadcdn.privatelink.msidentity.com
aadgv6.ppe.windows.net
aadgv6.ppe.windows.net
aadgv6.windows.net
aadgv6.windows.net
aadg.windows.net

(kali@kali)-[~]
$ grep -Ei '^(^|\.)hilton\.com$' "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_raw.txt" \
| tr '[:upper:]' '[:lower:]' | sort -u \
> "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_hilton_com.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_hilton_com.txt" 86 head -n 10 "$HOME/recopilacion/hilton.com/05_footprinting/cero_tls_hilton_com.txt"
68 /home/kali/recopilacion/hilton.com/05_footprinting/cero_tls_hilton_com.txt
3.hilton.com
alumni.hilton.com
api.asiapac.hilton.com
ar.hilton.com
austin.hilton.com
beacon.hilton.com
cr.hilton.com
cs.hilton.com
dms.hilton.com
events.hilton.com
```

Anexos generados (para el ZIP de outputs CLI)

- 05_footprinting/cero_tls_raw.txt
- 05_footprinting/cero_tls_hilton_com.txt

Web scraping / crawling (katana)

Objetivo del paso

El objetivo de esta fase es ampliar el reconocimiento vertical obteniendo **URLs y rutas expuestas públicamente** a partir de fuentes habituales de indexación: **robots.txt** y **sitemap.xml**. En organizaciones grandes, los sitemaps suelen estar estructurados como índices que referencian múltiples sitemaps por idioma, región o tipo de contenido. Esto permite descubrir de forma eficiente una gran cantidad de endpoints potenciales (páginas, recursos y rutas) que luego pueden aportar nuevas pistas (subdominios, patrones de URL, directorios, endpoints funcionales) para validación y fases posteriores.

Herramienta empleada

Se utiliza **katana** como crawler/scrapper: ejecución silenciosa (**-silent**), soporte JavaScript crawl (**-jc**) y obtención de URLs desde **robots.txt** y **sitemap.xml**.

Ejecución (comando exacto utilizado)

Se ejecutó Katana alimentándolo por stdin con el dominio objetivo y guardando la salida en fichero:

- Output generado:
 - ~/recopilacion/hilton.com/05_footprinting/katanaoutput.txt

En el entorno utilizado, el flag **-kf** requirió especificar los valores por separado (misma funcionalidad: **robotstxt** y **sitemapxml**)

Resultado obtenido

El output generado contiene una cantidad elevada de URLs, lo cual es consistente con la presencia de **sitemaps de gran volumen** (por idioma/región/segmento). Durante la ejecución se observó que Katana enumeraba múltiples ficheros **sitemap-*.xml** (por ejemplo por país/idioma), lo que explica el crecimiento rápido del listado.

Tras finalizar la ejecución, el fichero **katanaoutput.txt** contenía **1493** líneas.

Normalización y depuración del output

Para asegurar consistencia y preparar el resultado para consolidación final al término del Footprinting, se generó una versión depurada:

- conversión a minúsculas,
- eliminación de posibles retornos `\r`,
- ordenación y deduplicación.
- Output depurado:
 - `~/recopilacion/hilton.com/05_footprinting/katana_clean.txt`

(El recuento final queda registrado mediante `wc -l` como control de calidad).

Control de calidad (QC)

- Output raw: `katanaoutput.txt` (1493 líneas)
- Output clean: `katana_clean.txt` (deduplicado/normalizado)
- Observación: el alto volumen es coherente con sitemap index + múltiples sitemaps derivados, típico en dominios corporativos grandes.

Evidencia

```
(kali@kali)-[~]
$ echo hilton.com | katana -silent -jc -o "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt" -kf robotstxt
-kf sitemapxml
https://www.hilton.com/sitemap/vi/sitemap-vi.xml
https://www.hilton.com/sitemap/zh-hant/sitemap-zh-hant.xml
https://www.hilton.com/sitemap/es-co/sitemap-es-co.xml
https://www.hilton.com/sitemap/pt-pt/sitemap-pt-pt.xml
https://www.hilton.com/sitemap/fr-ca/sitemap-fr-ca.xml
https://www.hilton.com/sitemap/es-es/sitemap-es-es.xml
https://www.hilton.com/sitemap/es-mx/sitemap-es-mx.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in.xml
https://www.hilton.com/sitemap/zh-hans/sitemap-zh-hans.xml
https://www.hilton.com/sitemap/tr/sitemap-tr.xml
https://www.hilton.com/sitemap/es-es/sitemap-es-es-cpm-001.xml
https://www.hilton.com/sitemap/fr-ca/sitemap-fr-ca-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th.xml
https://www.hilton.com/sitemap/es-co/sitemap-es-co-cpm-001.xml
https://www.hilton.com/sitemap/pt-pt/sitemap-pt-pt-cpm-001.xml
https://www.hilton.com/sitemap/zh-hant/sitemap-zh-hant-cpm-001.xml
https://www.hilton.com/sitemap/vi/sitemap-vi-cpm-001.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar-cpm-001.xml
https://www.hilton.com/sitemap/es-mx/sitemap-es-mx-cpm-001.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in-cpm-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-prop-nd-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-prop-id-001.xml
https://www.hilton.com/sitemap/zh-hans/sitemap-zh-hans-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ey-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-nd-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-id-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ua-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-po-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ol-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gu-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-sa-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-py-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ou-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-wa-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-up-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-lx-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-lx-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ru-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-es-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-pe-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-qq-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hw-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hw-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-004.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-dt-001.xml
```



```

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt"
1493 /home/kali/recopilacion/hilton.com/05_footprinting/katanaoutput.txt

(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt" \
| tr '[:upper:]' '[:lower:]' \
| sed 's/\r$//' \
| sort -u \
> "$HOME/recopilacion/hilton.com/05_footprinting/katana_clean.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/katana_clean.txt" 66 head -n 10 "$HOME/recopilacion/hilton.com/05
_footprinting/katana_clean.txt"
1493 /home/kali/recopilacion/hilton.com/05_footprinting/katana_clean.txt
https://hilton.com
https://www.hilton.com/sitemap/ar/sitemap-ar.xml
https://www.hilton.com/sitemap/bg/sitemap-bg.xml
https://www.hilton.com/sitemap/cs/sitemap-cs.xml
https://www.hilton.com/sitemap/de/sitemap-de.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in-cpm-001.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in.xml
https://www.hilton.com/sitemap/en/sitemap-en.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar-cpm-001.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar.xml

```

Anexos generados (para el ZIP de outputs CLI)

- 05_footprinting/katanaoutput.txt
- 05_footprinting/katana_clean.txt

Certificate Transparency logs (ctfr)

Objetivo del paso

El objetivo de esta fase es enumerar subdominios asociados a **hilton.com** mediante **Certificate Transparency (CT)**. Los registros CT recogen nombres incluidos en certificados TLS emitidos públicamente, lo que permite descubrir subdominios que no siempre aparecen por DNS bruteforce o crawling. Es una fuente muy valiosa para reconocimiento vertical porque suele revelar entornos (por ejemplo **stage**, **dev**, **adfs**, marcas o regiones) que amplían la superficie a validar.

Herramienta empleada

Se utiliza **ctfr** para consultar fuentes CT (por ejemplo, **crt.sh** y similares) y extraer nombres asociados al dominio objetivo.

Ejecución (comando exacto utilizado)

Se ejecutó CTFR contra el dominio raíz y se guardó el resultado como anexo:

- Output raw:
 - `~/recopilacion/hilton.com/05_footprinting/ctfr_raw.txt`

Normalización y depuración del output

El output raw puede incluir:

- entradas con wildcard (***.dominio**),
- duplicados,
- diferencias de mayúsculas/minúsculas,
- retornos de carro.

Por ello se generó un fichero “clean” aplicando:

- eliminación de ***.**,
- normalización a minúsculas,
- ordenación y deduplicación.
- Output clean:
 - `~/recopilacion/hilton.com/05_footprinting/ctfr_clean.txt`

Resultado obtenido

- **ctfr_raw.txt: 1190** líneas
- **ctfr_clean.txt: 757** líneas (únicas tras limpieza)

Ejemplos representativos de subdominios detectados incluyen entradas como **adfs.hilton.com** o variaciones regionales y de marca. Es esperable que CT logs contengan subdominios que luego resulten no resolubles o no accesibles, ya que un nombre puede aparecer en un certificado aunque el servicio ya no esté activo.

Control de calidad (QC)

- Se conservaron ambos ficheros (raw y clean) para trazabilidad.
- La reducción de 1190 → 757 confirma que había duplicados y/o variantes de representación, eliminados en la limpieza.
- Nota operativa: la “utilidad” de cada subdominio se decidirá en la fase de validación/targets (resolución, vivo, scope).

Evidencia (captura)

```
(kali@kali)-[~]
└─$ echo hilton.com | katana -silent -jc -o "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt" -kf robotstxt
-kf sitemapxml
https://www.hilton.com/sitemap/vi/sitemap-vi.xml
https://www.hilton.com/sitemap/zh-hant/sitemap-zh-hant.xml
https://www.hilton.com/sitemap/es-co/sitemap-es-co.xml
https://www.hilton.com/sitemap/pt-pt/sitemap-pt-pt.xml
https://www.hilton.com/sitemap/fr-ca/sitemap-fr-ca.xml
https://www.hilton.com/sitemap/es-es/sitemap-es-es.xml
https://www.hilton.com/sitemap/es-mx/sitemap-es-mx.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in.xml
https://www.hilton.com/sitemap/zh-hans/sitemap-zh-hans.xml
https://www.hilton.com/sitemap/tr/sitemap-tr.xml
https://www.hilton.com/sitemap/es-es/sitemap-es-es-cpm-001.xml
https://www.hilton.com/sitemap/fr-ca/sitemap-fr-ca-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th.xml
https://www.hilton.com/sitemap/es-co/sitemap-es-co-cpm-001.xml
https://www.hilton.com/sitemap/pt-pt/sitemap-pt-pt-cpm-001.xml
https://www.hilton.com/sitemap/zh-hant/sitemap-zh-hant-cpm-001.xml
https://www.hilton.com/sitemap/vi/sitemap-vi-cpm-001.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar-cpm-001.xml
https://www.hilton.com/sitemap/es-mx/sitemap-es-mx-cpm-001.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in-cpm-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-prop-nd-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-prop-id-001.xml
https://www.hilton.com/sitemap/zh-hans/sitemap-zh-hans-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ey-001.xml
https://www.hilton.com/sitemap/tr/sitemap-tr-cpm-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-nd-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-id-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ua-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-po-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ol-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gu-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-sa-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-py-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ou-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-wa-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-up-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-lx-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-lx-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ru-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-es-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-pe-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-qq-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hw-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hw-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-ht-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-001.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-004.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-gi-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-002.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-hi-003.xml
https://www.hilton.com/sitemap/th/sitemap-th-prop-dt-001.xml
```

```

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt"
1493 /home/kali/recopilacion/hilton.com/05_footprinting/katanaoutput.txt

(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/05_footprinting/katanaoutput.txt" \
| tr '[:upper:]' '[:lower:]' \
| sed 's/\r$//' \
| sort -u \
> "$HOME/recopilacion/hilton.com/05_footprinting/katana_clean.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/katana_clean.txt" 66 head -n 10 "$HOME/recopilacion/hilton.com/05
_footprinting/katana_clean.txt"
1493 /home/kali/recopilacion/hilton.com/05_footprinting/katana_clean.txt
https://hilton.com
https://www.hilton.com/sitemap/ar/sitemap-ar.xml
https://www.hilton.com/sitemap/bg/sitemap-bg.xml
https://www.hilton.com/sitemap/cs/sitemap-cs.xml
https://www.hilton.com/sitemap/de/sitemap-de.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in-cpm-001.xml
https://www.hilton.com/sitemap/en-in/sitemap-en-in.xml
https://www.hilton.com/sitemap/en/sitemap-en.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar-cpm-001.xml
https://www.hilton.com/sitemap/es-ar/sitemap-es-ar.xml

```

Anexos generados (para el ZIP de outputs CLI)

- 05_footprinting/ctfr_raw.txt
- 05_footprinting/ctfr_clean.txt

Archivos web y caché (gau)

Objetivo del paso

El objetivo de esta fase es recuperar URLs históricas y actuales asociadas al dominio objetivo utilizando fuentes de archivo y caché (por ejemplo, índices históricos y fuentes públicas de URLs). Esta técnica es especialmente útil para reconocimiento porque permite descubrir:

- rutas que ya no están enlazadas desde la web actual,
- endpoints antiguos,
- patrones de URL repetidos (parámetros, paths, robots, etc.),
- y subdominios/hosts que aparecen como origen de URLs.

En combinación con el resto de técnicas del reconocimiento vertical, GAU aporta una visión “temporal” del dominio: lo que ha estado publicado o indexado, no solo lo que se ve hoy.

Herramienta empleada

Se utiliza **gau** (GetAllUrls). En tu ejecución aparece el aviso de configuración inexistente (~/.gau.toml), lo cual no es un error: la herramienta continúa utilizando configuración por defecto.

Ejecución (comando exacto utilizado)

Se ejecutó GAU inicialmente sobre el dominio raíz sin resultados, y se repitió siguiendo un enfoque más completo, incorporando subdominios:

- Ejecución con cobertura ampliada (la que produjo resultados):
 - `gau --subs hilton.com > ~/recopilacion/hilton.com/05_footprinting/gau_raw.txt`

Output generado:

- `~/recopilacion/hilton.com/05_footprinting/gau_raw.txt`

Resultado obtenido

- `gau_raw.txt`: **66.468** líneas
Estas URLs incluyen recursos del dominio principal y de múltiples hosts asociados (por ejemplo entradas como `http://api.hilton.com/`, `http://www.hilton.com/robots.txt`, etc.), lo cual es coherente con el uso de `--subs`.

Normalización y depuración del output

Para asegurar consistencia y preparar el conjunto para consolidación final, se generó un fichero “clean” aplicando:

- normalización a minúsculas,
- eliminación de retornos `\r` si existieran,
- ordenación y deduplicación.

Output depurado:

- `~/recopilacion/hilton.com/05_footprinting/gau_clean.txt`

Resultado:

- `gau_clean.txt`: **65.278** líneas (únicas tras deduplicación)

Control de calidad (QC)

- Raw: 66.468
- Clean: 65.278
La reducción es consistente con duplicados por variaciones de formato, repetición de URLs en distintas fuentes o diferencias de capitalización.

Nota metodológica

En esta fase aún no se decide qué URLs o hosts son “objetivos finales”. GAU produce un repositorio amplio de evidencias que se utilizará:

- para extraer hosts/subdominios relevantes,
- para identificar rutas interesantes,
- y para alimentar la validación y priorización en fases posteriores.

El filtrado por scope (incluyendo exclusiones específicas del programa) se aplicará cuando construyamos la lista final de objetivos.

Evidencia (captura)

```

(kali㉿kali)-[~]
$ gau hilton.com > "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt"
WARN[0000] error reading config: Config file /home/kali/.gau.toml not found, using default config
ls -la "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" 86 wc -l "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" 86 head -n 10 "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" 86
^C

(kali㉿kali)-[~]
$ ls -la "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" 86 wc -l "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" 86 head -n 10 "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt"
-rw-rw-r-- 1 kali kali 0 Mar 4 09:25 /home/kali/recopilacion/hilton.com/05_footprinting/gau_raw.txt
0 /home/kali/recopilacion/hilton.com/05_footprinting/gau_raw.txt

(kali㉿kali)-[~]
$ gau --subs hilton.com > "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt"
WARN[0000] error reading config: Config file /home/kali/.gau.toml not found, using default config

(kali㉿kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt"
66468 /home/kali/recopilacion/hilton.com/05_footprinting/gau_raw.txt

(kali㉿kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" \
| tr '[:upper:]' '[:lower:]' \
| sed 's/\r$//' \
| sort -u \
> "$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt"

(kali㉿kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt" 86 head -n 10 "$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt"
65278 /home/kali/recopilacion/hilton.com/05_footprinting/gau_clean.txt
http://1.hilton.com/
http://a1.hilton.com/
http://ad.hilton.com/
http://amer.hilton.com/
http://api.hilton.com/
http://app.app.hilton.com/
http://app.hilton.com/
http://assets.hilton.com/
http://atlassian-app.eu.hilton.com/
http://aus.amer.hilton.com/

(kali㉿kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/05_footprinting/gau_raw.txt" \
"$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt" \
86 head -n 5 "$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt" \
86 tail -n 5 "$HOME/recopilacion/hilton.com/05_footprinting/gau_clean.txt"
66468 /home/kali/recopilacion/hilton.com/05_footprinting/gau_raw.txt
65278 /home/kali/recopilacion/hilton.com/05_footprinting/gau_clean.txt
131746 total
http://1.hilton.com/
http://a1.hilton.com/
http://ad.hilton.com/
http://amer.hilton.com/
http://api.hilton.com/
http://www.hilton.com/en/p/hilton
http://www.hilton.com/robots.txt
http://www.my-event.hilton.com/rduanhx-t9s-56785ab2-15be-4cd6-87c8-aac07389bd62/
http://www.stlouisairport.hilton.com/
http://www.stlouisairport.hilton.com/robots.txt

```

Anexos generados (para el ZIP de outputs CLI)

- 05_footprinting/gau_raw.txt
- 05_footprinting/gau_clean.txt

6. Fingerprint

Validar subdominios vivos/online (httpx)

Objetivo del paso

El objetivo de esta fase es transformar el resultado del Footprinting (lista amplia de subdominios candidatos) en una lista operativa de **activos realmente accesibles por HTTP/HTTPS**. Esta validación es necesaria antes de cualquier fingerprinting más profundo o escaneo de puertos, porque reduce ruido: muchos subdominios enumerados pueden no estar activos, no exponer web o estar temporalmente inaccesibles.

En términos metodológicos, **httpx** permite:

- confirmar disponibilidad web (HTTP/HTTPS),
- estandarizar un inventario de “vivos”,
- y preparar inputs limpios para las siguientes etapas (por ejemplo, port scanning y tecnologías).

Input utilizado

Se utilizó como entrada la lista consolidada resultante del cierre de Footprinting:

- `~/recopilacion/hilton.com/06_targets/footprinting_subdomains_raw.txt` (842 subdominios candidatos)

Ejecución (comando exacto utilizado)

Se ejecutó **httpx** en modo silencioso para generar salida limpia y se guardó el resultado en fichero:

- Output raw:
 - `~/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt`

Posteriormente se normalizó y deduplicó para asegurar consistencia:

- Output clean (URLs vivas normalizadas):
 - `~/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt`

Limpieza para lista de hosts (eliminar **http/https**)

Para preparar el siguiente paso de escaneo de puertos (Nmap/Masscan) y mantener la coherencia con la metodología de las clases, se generó una lista de **dominios/hosts** eliminando el esquema **http://https://** y quedándose únicamente con el dominio:

- Lista final de dominios vivos (hosts):
 - `~/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt`

Resultado obtenido:

- `httpx_domains.txt`: **221** dominios vivos/online.

Control de calidad (QC)

- Input: `footprinting_subdomains_raw.txt` (842)
- Output final (hosts vivos): `httpx_domains.txt` (221)
- Decisión metodológica: conservar `httpx_clean.txt` (URLs) como evidencia y trabajar con `httpx_domains.txt` (hosts) como input para escaneo de puertos y herramientas posteriores.

Evidencia (captura)

```
(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/06_targets/footprinting_subdomains_raw.txt" | httpx -silent > "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt" 66 head -n 10 "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt"
223 /home/kali/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt
https://apac.hilton.com
https://api-cr.hilton.com
https://api.asiapac.hilton.com
https://api-cr-stage.hilton.com
https://alumni.hilton.com
https://ar.hilton.com
https://a1.hilton.com
https://acrl.hilton.com
https://aloha-1.hilton.com
https://aloha.hilton.com

(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_raw.txt" \
| tr '[:upper:]' '[:lower:]' \
| sed 's/^r$//' \
| sort -u \
> "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt" 66 tail -n 5 "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt"
223 /home/kali/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt
http://www.teammembers.hilton.com
http://www.tir.hilton.com
http://www.westloop.hilton.com
http://xd.hilton.com
http://youth.hilton.com

(kali@kali)-[~]
$ cat "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_clean.txt" | unfurl --unique domains > "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt" 66 head -n 10 "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt"
221 /home/kali/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt
aaa.hilton.com
alexandria.hilton.com
amaze.hilton.com
amex.hilton.com
atlanta.hilton.com
autodiscover.hilton.com
bali.hilton.com
bcm.hilton.com
bd.hilton.com
beijing.hilton.com
```

Anexos generados (para el ZIP de outputs CLI)

- 07_fingerprinting/httpx_raw.txt
- 07_fingerprinting/httpx_clean.txt
- 07_fingerprinting/httpx_domains.txt

Escaneo de puertos — Masscan / Nmap

Masscan

Objetivo del paso El objetivo de esta fase es obtener una **visión rápida de la superficie de servicios expuestos** en los activos vivos identificados previamente. Se utiliza Masscan porque permite escanear de forma eficiente un conjunto amplio de objetivos y detectar **puertos abiertos**. Este resultado sirve para:

- identificar servicios no web relevantes (correo, SSH, FTP, SMB, DNS, etc.),
- priorizar qué objetivos merecen un análisis más detallado,
- y preparar un subconjunto para verificación con Nmap (servicio/versión).

Input y preparación previa (dominios → IPs)

Masscan requiere **direcciones IP**, por lo que se realizó una resolución DNS previa a partir de la lista de dominios vivos validada en 6.1 ([httpx_domains.txt](#)). Para ello:

- se resolvieron registros A con [dnsx](#) en formato “dominio → IP”,
- se extrajeron las IPs,
- se limpiaron posibles caracteres de formato (códigos ANSI),
- y se deduplicaron.

Resultado de la preparación:

- Lista final de IPs para escaneo:
 - [~/recopilacion/hilton.com/07_fingerprinting/ips_unique_clean.txt](#)
- Tamaño verificado: **137** IPs únicas.

(Esta parte se documenta con la captura donde se ve el recuento y una muestra de la lista).

Ejecución (comando exacto utilizado)

Para mantener el escaneo más prudente, se ejecutó Masscan sobre el **top 100 puertos** con un rate moderado:

- Output generado:

- ~/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log

Resultado obtenido (puertos detectados)

El fichero `masscan_top100.log` contiene **285** líneas, incluyendo la cabecera y eventos “open”. A partir de los resultados, los puertos abiertos más frecuentes fueron:

- **80/tcp**: 113 apariciones
- **443/tcp**: 112 apariciones
- **587/tcp**: 16 (SMTP submission)
- **143/tcp**: 16 (IMAP)
- **110/tcp**: 16 (POP3)
- **465/tcp**: 2 (SMTPS)
- **445/tcp**: 2 (SMB)
- **21/tcp**: 2 (FTP)
- **53/tcp**: 1 (DNS)
- **22/tcp**: 1 (SSH)
- **444/tcp**: 2 (puerto no estándar; requiere verificación)

Interpretación preliminar:

- La gran mayoría de exposición es **web** (80/443), lo esperable en un dominio corporativo amplio.
- Se observa también exposición relevante de **servicios de correo** (110/143/465/587), lo cual es consistente con infraestructura de email.
- Aparecen puertos menos comunes en el conjunto (21, 22, 53, 445, 444) que son especialmente interesantes porque suelen corresponder a servicios de administración o infraestructura y deben verificarse con Nmap (para confirmar servicio real y contexto).

Preparación de subset para verificación (targets no web)

Para enfocar el análisis detallado y mantener discreción, se generó un fichero con objetivos “no web” (puertos distintos de 80/443), en formato `IP:PUERTO`:

- ~/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_targets.txt

Este fichero se utiliza como entrada directa para Nmap, reduciendo el volumen y aumentando la calidad de la evidencia.

Control de calidad (QC)

- IPs escaneadas (input): `ips_unique_clean.txt` (137)
- Output Masscan: `masscan_top100.log` (285 líneas)
- Resumen de puertos: predominio 80/443, presencia significativa de puertos de correo y un conjunto reducido de puertos de infraestructura.
- Subset para Nmap: `masscan_nonweb_targets.txt` (targets no web deduplicados).

Evidencia

```
(kali@kali)-[~]
└─$ # 1) Dominios vivos (sin http/https)
wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt"
head -n 3 "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt"

# 2) Resolver A records con dnsx (dominio → IP) y mostrar muestra
dnsx -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt" -a -resp -silent | head -n 5

# 3) Generar fichero dnsx_a_resp.txt (para dejar evidencia guardada)
dnsx -l "$HOME/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt" -a -resp -silent > "$HOME/recopilacion/hilton.com/07_fingerprinting/dnsx_a_resp.txt"
wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/dnsx_a_resp.txt"
head -n 3 "$HOME/recopilacion/hilton.com/07_fingerprinting/dnsx_a_resp.txt"

# 4) Extraer IPs y limpiar ANSI → ips_unique_clean.txt
cat "$HOME/recopilacion/hilton.com/07_fingerprinting/dnsx_a_resp.txt" \
| sed -r 's/\x1B\[([0-9];)*[a-zA-Z]//g' \
| grep -Eo '([0-9]{1,3}\.){3}[0-9]{1,3}' \
| sort -u \
> "$HOME/recopilacion/hilton.com/07_fingerprinting/ips_unique_clean.txt"

wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/ips_unique_clean.txt"
head -n 5 "$HOME/recopilacion/hilton.com/07_fingerprinting/ips_unique_clean.txt"
221 /home/kali/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt
aaa.hilton.com
alexandria.hilton.com
amaze.hilton.com
api.asiapac.hilton.com [A] [110.164.21.8]
api.asiapac.hilton.com [A] [110.164.21.136]
amex.hilton.com [A] [167.187.200.18]
bd.hilton.com [A] [167.187.200.18]
luxurysuites.hilton.com [A] [167.187.200.24]
293 /home/kali/recopilacion/hilton.com/07_fingerprinting/dnsx_a_resp.txt
lima.hilton.com [A] [167.187.200.18]
lobbylite.hilton.com [A] [23.53.91.53]
brandstandardsstage.hilton.com [A] [167.187.100.44]
123 /home/kali/recopilacion/hilton.com/07_fingerprinting/ips_unique_clean.txt
100.51.213.79
104.18.10.9
104.18.11.9
104.18.38.56
104.18.39.66
```

```

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log" 66 head -n 30 "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log"
285 /home/kali/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log
#masscan
open tcp 445 16.15.207.175 1772709660
open tcp 443 4.236.214.22 1772709661
open tcp 443 54.81.116.232 1772709661
open tcp 587 52.98.54.130 1772709661
open tcp 443 167.187.100.59 1772709661
open tcp 443 23.11.200.136 1772709662
open tcp 80 23.39.90.5 1772709662
open tcp 80 54.230.41.23 1772709662
open tcp 443 20.190.148.167 1772709662
open tcp 80 172.64.148.190 1772709662
open tcp 443 184.73.191.42 1772709663
open tcp 443 34.174.3.100 1772709663
open tcp 443 167.187.101.252 1772709663
open tcp 443 20.190.148.163 1772709663
open tcp 443 167.187.101.96 1772709664
open tcp 143 40.99.33.130 1772709664
open tcp 443 54.92.242.204 1772709664
open tcp 443 100.51.213.79 1772709664
open tcp 80 18.239.134.94 1772709665
open tcp 80 54.81.116.232 1772709665
open tcp 443 44.208.138.79 1772709665
open tcp 443 20.214.131.176 1772709665
open tcp 80 167.187.100.148 1772709665
open tcp 443 44.238.17.167 1772709665
open tcp 443 51.24.48.133 1772709665
open tcp 143 40.104.72.114 1772709665
open tcp 443 167.187.103.217 1772709666
open tcp 80 44.238.17.167 1772709666
open tcp 143 40.99.111.2 1772709666

(kali@kali)-[~]
$ grep '^open ' "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log" | awk '{print $3}' | sort | uniq -c
| sort -nr | head -n 20
113 80
112 443
16 587
16 143
16 110
2 465
2 445
2 444
2 21
1 53
1 22

(kali@kali)-[~]
$ grep '^open ' "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_top100.log" \
| awk '$3 != 80 66 $3 != 443 {print $4 ":" $3}' \
| sort -u \
> "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_targets.txt"

(kali@kali)-[~]
$ wc -l "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_targets.txt" 66 head -n 10 "$HOME/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_targets.txt"
58 /home/kali/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_targets.txt
110.4.45.227:110
110.4.45.227:143
110.4.45.227:21
110.4.45.227:465
110.4.45.227:53
110.4.45.227:587
16.15.178.77:444
16.15.178.77:445
16.15.207.175:444
16.15.207.175:445

```

Anexos generados (para el ZIP de outputs CLI)

- 07_fingerprinting/dnsx_a_resp.txt
- 07_fingerprinting/ips_unique_clean.txt
- 07_fingerprinting/masscan_top100.log
- 07_fingerprinting/masscan_nonweb_targets.txt

Nmap

Objetivo del paso

El objetivo de esta fase es **verificar y enriquecer** los hallazgos obtenidos con Masscan. Mientras Masscan detecta puertos abiertos de forma rápida, Nmap permite confirmar el estado del puerto y obtener **servicio/versión** y evidencia adicional (banners y scripts por defecto), mejorando la calidad del inventario técnico sin realizar explotación.

Input utilizado

Se utilizaron IPs derivadas del subset “no web” detectado en Masscan. Dado que Nmap no acepta **IP:PUERTO** como entrada con **-iL**, se generó una lista de IPs únicas:

- `~/recopilacion/hilton.com/07_fingerprinting/masscan_nonweb_ips.txt`

Ejecución (comando exacto utilizado)

Se ejecutó Nmap limitando el análisis a los puertos no-web detectados por Masscan, con detección de servicio/versión y scripts por defecto:

- Output generado:
 - `~/recopilacion/hilton.com/07_fingerprinting/nmap_nonweb.txt`

Resultado obtenido (resumen)

- Hosts con salida estructurada (tabla PORT/STATE/SERVICE): **19**.
- Puertos abiertos observados con mayor frecuencia:
 - **587/tcp** (SMTP submission): 16
 - **143/tcp** (IMAP): 16
 - **110/tcp** (POP3): 16
 - y en menor medida **21/tcp (FTP)**, **445/tcp**, **444/tcp**, **465/tcp**, **53/tcp**, **22/tcp**.

Hallazgos representativos

- Se identificó al menos un host con stack de correo completo (ejemplo: **Postfix** en 465/587 y **Dovecot** en 110/143), además de **ProFTPD** en 21/tcp, lo que confirma exposición de servicios de correo/FTP en el subconjunto analizado.
- En algunas IPs se observó 445/tcp como abierto pero sin negociación SMB2 en scripts (**Protocol negotiation failed**), por lo que el servicio no queda confirmado como SMB2 y se registra como hallazgo a validar si fuese necesario en una fase posterior (sin explotación).

Control de calidad (QC)

- Nmap se ejecutó únicamente sobre puertos no-web para mantener el análisis acotado.
- Se generó un output persistente (**nmap_nonweb.txt**) para trazabilidad y anexos.

Evidencia (captura)

```

(kali@kali)-[~]
$ grep -c "PORT *STATE *SERVICE" "$HOME/recopilacion/hilton.com/07_fingerprinting/nmap_nonweb.txt"
19

(kali@kali)-[~]
$ grep -E "[0-9]+/(tcp|udp)[[:space:]]+open" "$HOME/recopilacion/hilton.com/07_fingerprinting/nmap_nonweb.txt" \
| awk '{print $1}' | sort | uniq -c | sort -nr
16 587/tcp
16 143/tcp
16 110/tcp
2 465/tcp
2 445/tcp
2 444/tcp
2 21/tcp
1 53/tcp
1 22/tcp

(kali@kali)-[~]
$ awk 'BEGIN{RS="Nmap scan report for "; ORS=""} NR==2{print "Nmap scan report for "$0} NR==3{print "\n---\nNmap scan re
port for "$0} NR==4{print "\n---\nNmap scan report for "$0}' \
"$HOME/recopilacion/hilton.com/07_fingerprinting/nmap_nonweb.txt"
Nmap scan report for sp162.mschoosing.cloud (110.4.45.227)
Host is up (0.027s latency).

PORT      STATE      SERVICE      VERSION
21/tcp    open       ftp           ProFTPD
|_ ssl-cert: Subject: commonName=sp162.mschoosing.cloud
|_ Subject Alternative Name: DNS:sp162.mschoosing.cloud
|_ Not valid before: 2026-01-31T14:15:44
|_ Not valid after: 2026-05-01T14:15:43
|_ ssl-date: TLS randomness does not represent time
|_ tls-nextprotoneg:
|_ ftp
|_ tls-alpn:
|_ ftp
22/tcp    filtered  ssh
53/tcp    open       domain       (unknown banner: none)
|_ dns-nsid:
|_ bind.version: none
|_ fingerprint-strings:
|_   DNSVersionBindReqTCP:
|_     version
|_     bind
|_     none
110/tcp   open       pop3          Dovecot pop3d
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=sp162.mschoosing.cloud
|_ Subject Alternative Name: DNS:sp162.mschoosing.cloud
|_ Not valid before: 2026-01-31T14:15:44
|_ Not valid after: 2026-05-01T14:15:43
|_ pop3-capabilities: STLS SASL(PLAIN LOGIN DIGEST-MD5 CRAM-MD5) APOP CAPA AUTH-RESP-CODE USER RESP-CODES UIDL TOP PIPELINI
NG
143/tcp   open       imap          Dovecot imapd
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=sp162.mschoosing.cloud
|_ Subject Alternative Name: DNS:sp162.mschoosing.cloud
|_ Not valid before: 2026-01-31T14:15:44

```

Anexos generados (para ZIP de outputs CLI)

- 07_fingerprinting/masscan_nonweb_ips.txt
- 07_fingerprinting/nmap_nonweb.txt

Análisis visual y tecnología web (GoWitness)

Objetivo del paso

El objetivo de esta fase es obtener una **visión visual y rápida** de los dominios vivos identificados en 6.1, generando capturas de pantalla y un reporte navegable. Esto permite:

- identificar de forma eficiente portales, páginas de login, landing pages y errores comunes,
- detectar patrones (misma plantilla/CDN/WAF) y posibles activos de interés,
- y apoyar la priorización para análisis de tecnologías (WhatWeb) y pasos posteriores.

GoWitness se utiliza porque automatiza la captura y organización de evidencias, generando material altamente útil para el informe sin necesidad de visitar manualmente cada host.

Input utilizado

Se utilizó la lista de dominios vivos (sin `http/https`) obtenida tras `httpx` + limpieza con `unfurl`:

- `~/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt` (**221** dominios vivos)

Ejecución (comando exacto utilizado)

Se ejecutó GoWitness sobre la lista de dominios vivos, guardando resultados en base de datos local:

- `gowitness scan file -f
~/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt --write-db`

Durante la ejecución, GoWitness generó:

- una base de datos SQLite (para el reporte),
- y una carpeta con capturas (screenshots).

Exportación a la carpeta de trabajo (evidencia y trazabilidad)

Para mantener el proyecto autocontenido, se copiaron los artefactos generados por GoWitness a la carpeta del proyecto:

- Destino:

- `~/recopilacion/hilton.com/07_fingerprinting/gowitness/`
- Artefactos guardados:
 - `gowitness.sqlite3`
 - `screenshots/` (capturas en formato `.jpeg`)

Esto garantiza que el informe y sus anexos pueden ser reproducidos y revisados sin depender de rutas externas.

Visualización del reporte

Para revisar las capturas y explorar los resultados de forma ordenada, se levantó el servidor local del reporte:

- `gowitness report server`

GoWitness inició un servidor local en:

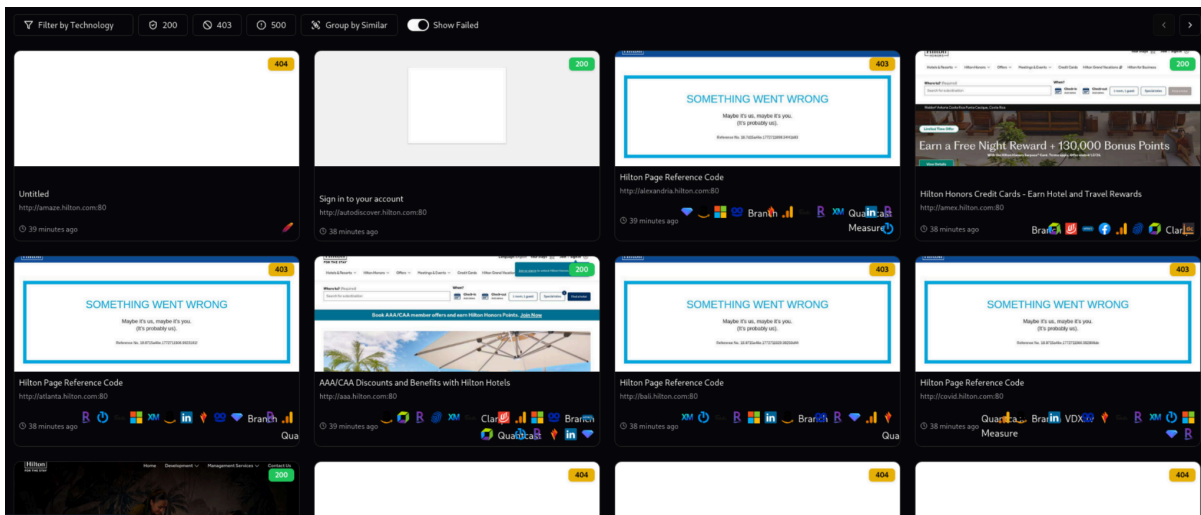
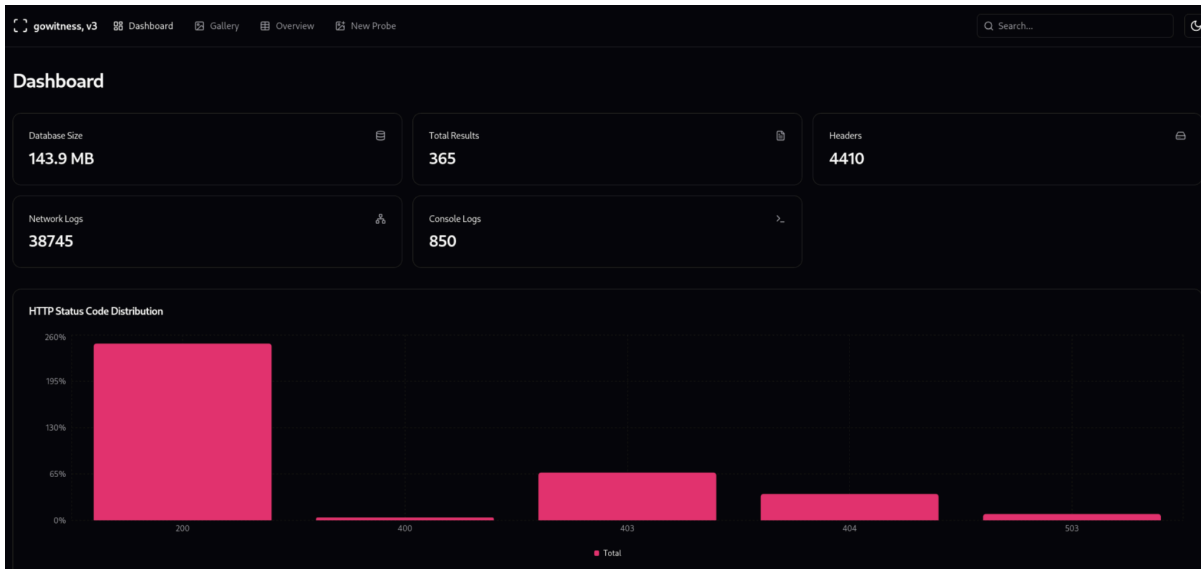
- `http://127.0.0.1:7171`

El reporte permite navegar por las capturas y revisar rápidamente el estado visual de cada dominio.

Control de calidad (QC)

- Input (dominios vivos): `httpx_domains.txt` (221)
- Artefactos generados y preservados:
 - `07_fingerprinting/gowitness/gowitness.sqlite3`
 - `07_fingerprinting/gowitness/screenshots/`
- Reporte local accesible: `127.0.0.1:7171`

Evidencia



Filter by URL or title...			All		
Actions	Code	URL	Title	Size	Protocol
View	404	http://amaze.hilton.com:80		0.16 KB	http/1.1
View	200	http://autodiscover.hilton.com:80	Sign in to your account	6.07 KB	h2
View	403	http://alexandria.hilton.com:80	Hilton Page Reference Code	0.13 KB	h2
View	200	http://amex.hilton.com:80	Hilton Honors Credit Cards - Earn Hotel and Travel Rewards	0.05 KB	h3
View	403	http://atlanta.hilton.com:80	Hilton Page Reference Code	0.02 KB	h3
View	200	http://aaa.hilton.com:80	AAA/CAA Discounts and Benefits with Hilton Hotels	2.11 KB	h2
View	403	http://bali.hilton.com:80	Hilton Page Reference Code	0.03 KB	h3
View	403	http://covid.hilton.com:80	Hilton Page Reference Code	0.03 KB	h3
View	200	http://development.hilton.com:80	Hotel and Resort Development Hilton	0.03 KB	h3
View	404	http://finance.hilton.com:80		0.16 KB	http/1.1
View	404	http://families.hilton.com:80		0.16 KB	http/1.1
View	404	http://fractal.hilton.com:80		0.16 KB	http/1.1
View	403	http://fonts.hilton.com:80	Hilton Page Reference Code	0.00 KB	h3
View	404	http://pki.hilton.com:80	404 Not Found	0.26 KB	http/1.1
View	404	http://rdf-dual-stg.hilton.com:80		0.16 KB	http/1.1
View	404	http://rdf-dual-stg.hilton.com:443		0.16 KB	http/1.1
View	404	http://a1.hilton.com:80	404	0.24 KB	http/1.1
View	400	http://a1.hilton.com:443	400 The plain HTTP request was sent to HTTPS port	0.15 KB	http/1.1
View	404	https://a1.hilton.com:443	404	0.13 KB	h2

Anexos generados (para ZIP de outputs/evidencias)

- `07_fingerprinting/gowitness/gowitness.sqlite3`
- `07_fingerprinting/gowitness/screenshots/`

6.4 Detección de WAFs (wafw00f)

Objetivo del paso

El objetivo de esta fase es identificar si los dominios web vivos están protegidos por **WAF/CDN/Reverse Proxy** (por ejemplo Akamai, CloudFront, F5, etc.). Esta información es clave para:

- comprender la arquitectura de exposición (edge/CDN vs backend),
- interpretar limitaciones de escaneo y posibles bloqueos,
- y ajustar expectativas en etapas posteriores (fuzzing, validación de vulnerabilidades), siempre dentro del scope.

Input utilizado

Se utilizó la lista de dominios vivos obtenida en 6.1:

- `~/recopilacion/hilton.com/07_fingerprinting/httpx_domains.txt` (**221** dominios)

Ejecución (comando exacto utilizado)

Se ejecutó `wafw00f` tal como propone el profesor (`wafw00f -i subdominios.txt`), guardando **stdout+stderr** en un fichero para trazabilidad (incluyendo errores por host no accesible):

- Output:
 - `~/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt`

Resultado obtenido (interpretación)

La herramienta produjo tres tipos de salida:

1. **Detección positiva de WAF** (`is behind ... WAF`)
Ejemplos observados:
 - `https://www.giftstatus.hilton.com` detrás de **Kona SiteDefender (Akamai)**.

- <https://www.htsc.hilton.com> detrás de **BIG-IP Local Traffic Manager (F5 Networks)**.
 - <https://www.jobs.hilton.com> detrás de **CloudFront (Amazon)**.
2. **No detección por firma genérica (No WAF detected by the generic detection)**
Este resultado no confirma ausencia de WAF; únicamente indica que wafw00f no pudo identificar un WAF con su heurística genérica para esos hosts.
 3. **Hosts no accesibles/intermitentes (appears to be down)**
En listas grandes es esperable que existan hosts que rechacen conexiones, tengan reglas específicas o estén intermitentes. Estos casos se registran como evidencia, pero no invalidan el procedimiento.

Control de calidad (QC)

- Input: [httpx_domains.txt](#) (221)
- Output persistente: [wafw00f_raw.txt](#) (incluye detecciones y errores).
- Se registran detecciones positivas y se conservan casos “down/no detect” como evidencia de comportamiento y límites de la herramienta.

Evidencia (captura)

Descubrimiento de contenido (ffuf)

Objetivo

Realizar descubrimiento de rutas/directorios no enlazados públicamente para localizar potenciales recursos con información sensible o superficies de ataque (endpoints administrativos, ficheros expuestos, rutas internas), utilizando una wordlist específica.

3. Recopilacion de informacion ...

Herramienta y criterios

Se emplea **ffuf** por su velocidad y capacidad de personalización, con concurrencia (`-t 20`) y filtrado por códigos HTTP relevantes (`-mc 200,401,403`). La wordlist se toma de **SecLists / Discovery / Web-Content**.

3. Recopilacion de informacion ...

Ejecución realizada (comandos y decisiones)

1. Selección y trazabilidad de wordlist (SecLists)

Se verificó la ruta local de SecLists y se seleccionó una wordlist existente dentro de **Discovery/Web-Content**, quedando fijada para trazabilidad en:

- `07_fingerprinting/ffuf_wordlist_selected.txt`
- Wordlist utilizada:
- `/usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt`

2. Ejecución “base” siguiendo el comando del profesor (dominio principal)

Se ejecutó ffuf siguiendo el patrón del profesor (con `-t 20` y `-mc 200,401,403`), guardando evidencias en JSON y log de consola:

- `07_fingerprinting/ffuf_hilton_com.json`
- `07_fingerprinting/ffuf_hilton_com_raw.txt`

Resultado observado: **0 coincidencias** (`results_count: 0`) a pesar de completar la wordlist, con algunos errores puntuales (indicados por ffuf en el resumen).

3. Análisis de causa (comportamiento HTTP del objetivo)

Se comprobó el comportamiento HTTP con `curl -I` para entender la ausencia de 200/401/403:

- `https://hilton.com/` respondía **301** redirigiendo a `https://www.hilton.com/`.
Esto explica que el matcher `-mc 200,401,403` no devolviera resultados, ya que la respuesta predominante no era una de las seleccionadas.

4. Validación del destino real y adaptación mínima operativa

Al comprobar `https://www.hilton.com/`, se observó nueva redirección **301** hacia `https://www.hilton.com/en/` y presencia de cookies típicas de mitigación/anti-bot. En consecuencia, se ejecutó ffuf sobre la base más realista del site:

- `https://www.hilton.com/en/FUZZ`

Resultado: el site respondió **403 uniforme** para prácticamente toda la wordlist (mismo tamaño de respuesta), generando una tasa de “matches” masiva no discriminante. Se cuantificó la uniformidad en el JSON:

- `status_counts: {403: 63048}`
 - Dos tamaños de respuesta casi idénticos dominantes (indicativo de página de “Access Denied” uniforme).
5. **Intento de reducción de ruido con auto-calibración y filtrado de 403**
Para intentar obtener únicamente respuestas que se desviaran del patrón uniforme de bloqueo, se ejecutó ffuf con:
- `-ac` (auto-calibración)
 - `-fc 403` (filtrado del ruido principal)

Outputs:

- `07_fingerprinting/ffuf_www_hilton_com_en_ac.json`
- `07_fingerprinting/ffuf_www_hilton_com_en_ac_raw.txt`

Resultado final: **0 coincidencias** (`results_count: 0`) tras filtrar 403 y calibrar, lo que indica que el WAF/anti-bot está impidiendo el descubrimiento de contenido mediante fuzzing de paths en este endpoint en estas condiciones.

Evidencias y anexos generados

(ubicación: `~/recopilacion/hilton.com/07_fingerprinting/`)

- `ffuf_wordlist_selected.txt` (wordlist usada)
- `ffuf_hilton_com.json`, `ffuf_hilton_com_raw.txt` (intento base en `hilton.com`)
- `ffuf_www_hilton_com_en.json`, `ffuf_www_hilton_com_en_raw.txt` (intento en `/en/` con 403 masivo)
- `ffuf_www_hilton_com_en_ac.json`, `ffuf_www_hilton_com_en_ac_raw.txt` (auto-calibración + filtrado 403)
- `ffuf_errors_tail.txt`, `ffuf_log_tail_200.txt` (trazas auxiliares para diagnóstico)
- `ffuf_errors_lines.txt` (resumen de “Errors:”)
- `ffuf_6_5_documentacion_evidencia.txt` y `ffuf_6_5_results_from_json.txt` (evidencias de extracción en la etapa inicial)

Conclusión

El fuzzing de paths con ffuf se ejecutó correctamente y con evidencias completas, pero el endpoint analizado presenta un comportamiento de redirección y, posteriormente, un **bloqueo uniforme (403) por WAF/anti-bot**, haciendo que la enumeración de contenido no sea discriminante. Por tanto, se considera el paso **completado** con resultado “no explotable por fuzzing directo” y se continúa con la siguiente fase del flujo (Análisis de vulnerabilidades con Nuclei), manteniendo todos los artefactos para anexos y reproducibilidad.

```
(kali@kali)-[~]
$ grep -E "is behind|appears to be down|No WAF detected" "$HOME/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt" | tail -n 30
ERROR:wafw00f:Site westloop.hilton.com appears to be down
ERROR:wafw00f:Site www1.hilton.com appears to be down
ERROR:wafw00f:Site www.ar.hilton.com appears to be down
ERROR:wafw00f:Site www.careers.hilton.com appears to be down
ERROR:wafw00f:Site www.covid-origin.hilton.com appears to be down
ERROR:wafw00f:Site www.digitalassetd.hilton.com appears to be down
ERROR:wafw00f:Site www.discover.hilton.com appears to be down
[+] The site https://www.giftstatus.hilton.com is behind Kona SiteDefender (Akamai) WAF.
[+] The site https://www.htsc.hilton.com is behind BIG-IP Local Traffic Manager (F5 Networks) WAF.
[+] The site https://www.jobs.hilton.com is behind Cloudfront (Amazon) WAF.
[-] No WAF detected by the generic detection
[-] No WAF detected by the generic detection
[-] No WAF detected by the generic detection
[-] No WAF detected by the generic detection
[-] No WAF detected by the generic detection
[-] No WAF detected by the generic detection
ERROR:wafw00f:Site www.families.hilton.com appears to be down
ERROR:wafw00f:Site www.finance.hilton.com appears to be down
ERROR:wafw00f:Site www.fractal.hilton.com appears to be down
ERROR:wafw00f:Site www.go.hilton.com appears to be down
ERROR:wafw00f:Site www.golf.hilton.com appears to be down
ERROR:wafw00f:Site www.groupguides.hilton.com appears to be down
ERROR:wafw00f:Site www.gtp.hilton.com appears to be down
ERROR:wafw00f:Site www.momvoyage.hilton.com appears to be down
ERROR:wafw00f:Site www.my.hilton.com appears to be down
ERROR:wafw00f:Site www.teammembers.hilton.com appears to be down
ERROR:wafw00f:Site www.tir.hilton.com appears to be down
ERROR:wafw00f:Site www.westloop.hilton.com appears to be down
ERROR:wafw00f:Site xd.hilton.com appears to be down
ERROR:wafw00f:Site youth.hilton.com appears to be down

(kali@kali)-[~]
$ grep -c "is behind" "$HOME/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt" 86 \
grep -c "No WAF detected" "$HOME/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt" 86 \
grep -c "appears to be down" "$HOME/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt" 86 \
grep "is behind" "$HOME/recopilacion/hilton.com/07_fingerprinting/wafw00f_raw.txt" | head -n 20
22
75
83
[+] The site https://digitalasset-delivery1.hilton.com is behind Cloudflare (Cloudflare Inc.) WAF.
[+] The site https://digitalassetd.hilton.com is behind Cloudflare (Cloudflare Inc.) WAF.
[+] The site https://dms.hilton.com is behind Cloudflare (Cloudflare Inc.) WAF.
[+] The site https://dmstest.hilton.com is behind Cloudflare (Cloudflare Inc.) WAF.
[+] The site https://doubletreedesignstudio.hilton.com is behind Azure Application Gateway (Microsoft) WAF.
[+] The site https://edge.hilton.com is behind Kona SiteDefender (Akamai) WAF.
[+] The site https://enterpriseenrollment.hilton.com is behind Azure Front Door (Microsoft) WAF.
[+] The site https://fitness.hilton.com is behind Azure Application Gateway (Microsoft) WAF.
[+] The site https://giftstatus.hilton.com is behind Kona SiteDefender (Akamai) WAF.
[+] The site https://groups.hilton.com is behind Cloudfront (Amazon) WAF.
[+] The site https://hiltondesignstudio.hilton.com is behind Azure Application Gateway (Microsoft) WAF.
[+] The site https://htsc.hilton.com is behind BIG-IP Local Traffic Manager (F5 Networks) WAF.
[+] The site https://ir.hilton.com is behind AWS Elastic Load Balancer (Amazon) WAF.
[+] The site https://jobs.hilton.com is behind Cloudfront (Amazon) WAF.
[+] The site https://map.hilton.com is behind Google Cloud App Armor (Google Cloud) WAF.
[+] The site https://mstr.hilton.com is behind AWS Elastic Load Balancer (Amazon) WAF.
[+] The site https://sez.hilton.com is behind Envoy (EnvoyProxy) WAF.
[+] The site https://teammembers.hilton.com is behind Cloudfront (Amazon) WAF.
[+] The site https://www.digitalasset-delivery1.hilton.com is behind Cloudflare (Cloudflare Inc.) WAF.
```

Anexos generados (para ZIP de outputs CLI)

- 07_fingerprinting/wafw00f_raw.txt

7. Analisis de vulnerabilidades

7.1 Análisis de vulnerabilidades web (Nuclei) — ejecución parcial por limitación de tiempo

En esta fase se utilizó **Nuclei (ProjectDiscovery)** para realizar un análisis automatizado de vulnerabilidades web sobre la lista de objetivos vivos obtenida en la etapa de fingerprinting (`07_fingerprinting/httpx_domains.txt`). La ejecución se realizó en Kali, empleando Nuclei v3.x y los templates oficiales de `projectdiscovery/nuclei-templates`, con salida dirigida a fichero para su trazabilidad en el informe (carpeta `08_vuln/`).

Durante la ejecución se observó un comportamiento consistente con infraestructuras protegidas por **CDN/WAF/controles anti-bot** y con subdominios que no aceptan conexiones o no resuelven de forma estable. Nuclei registró numerosos objetivos como **no responsivos** tras múltiples reintentos (“Skipped ... found unresponsive”), así como casos puntuales de resolución DNS fallida (“no address found for host”). Este patrón incrementa significativamente el tiempo total del escaneo debido a esperas por timeout y reintentos sobre objetivos inaccesibles o filtrados.

A pesar de haber mantenido el proceso en ejecución durante aproximadamente **tres horas**, el escaneo no alcanzó una finalización completa dentro del tiempo disponible para la práctica. Por esta razón, y con el objetivo de poder continuar con el flujo del ejercicio, se detuvo la ejecución y se dejó constancia de los **resultados parciales** disponibles hasta ese momento. En el intervalo ejecutado, no se identificaron hallazgos concluyentes que pudieran reportarse como vulnerabilidades confirmadas; no obstante, el hecho de no completar el 100% del escaneo implica que el análisis debe considerarse **parcial** y reanudable en una sesión posterior.

Como evidencia del trabajo realizado se adjuntan los artefactos generados (salida en `08_vuln/nuclei_raw.txt`, logs de consola si aplica y/o fichero de “resume/checkpoint” cuando se generó) para permitir la **reproducibilidad** y la reanudación del análisis con más tiempo o ajustando parámetros operativos (timeouts, reintentos, alcance por severidad).

```

(kali@kali)-[~/recopilacion/hilton.com]
$ cd ~/recopilacion/hilton.com 86 {
echo "=== NUCLEI 4.1 EVIDENCIA PARCIAL ==="
date
echo
echo "[NUCLEI VERSION]"
nuclei -version
echo
echo "[TARGETS LIST]"
echo "file: 07_fingerprinting/httpx_domains.txt"
wc -l 07_fingerprinting/httpx_domains.txt
echo
echo "[OUTPUT FILE STATUS]"
ls -lah 08_vuln/nuclei_raw.txt 2>/dev/null || true
echo
echo "[CONSOLE LOG (tail)]"
tail -n 80 08_vuln/nuclei_console_raw.txt 2>/dev/null || echo "nuclei_console_raw.txt no existe (no se ejecutó con tee)"
}
echo
echo "[RESUME FILES (last 3)]"
ls -lah ~/.cache/nuclei/resume-*.cfg 2>/dev/null | tail -n 3 || true
} | tee 08_vuln/nuclei_evidencia_parcial.txt
=== NUCLEI 4.1 EVIDENCIA PARCIAL ===
Sun Mar  8 04:27:00 AM EDT 2026

[NUCLEI VERSION]
[INF] Nuclei Engine Version: v3.7.0
[INF] Nuclei Config Directory: /home/kali/.config/nuclei
[INF] Nuclei Cache Directory: /home/kali/.cache/nuclei
[INF] PDCP Directory: /home/kali/.pdcp

[TARGETS LIST]
file: 07_fingerprinting/httpx_domains.txt
221 07_fingerprinting/httpx_domains.txt

[OUTPUT FILE STATUS]
-rw-rw-r-- 1 kali kali 0 Mar  8 03:59 08_vuln/nuclei_raw.txt

[CONSOLE LOG (tail)]
[INF] Skipped seoul.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped tokyo.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped ta.hilton.com:80 from target list as found unresponsive 32 times
[INF] Skipped text.hilton.com:80 from target list as found unresponsive 31 times
[INF] Skipped uber.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped up.hilton.com:80 from target list as found unresponsive 30 times
[ERR] Could not unmarshal interaction data interaction: server.Interaction.Protocol: ReadString: invalid control character found: 17, error found in #10 byte of ...|rotocol":"dns*Q*7$|... , bigger context ...|{"protocol":"dns*Q*7$*}*G 6
>
...j...Tc6Az*,...b...9j*...|...
[ERR] Could not unmarshal interaction data interaction: server.Interaction.Protocol: ReadString: invalid control character found: 30, error found in #10 byte of ...|rotocol":"dns6Z_:Y|... , bigger context ...|{"protocol":"dns6Z_:Yo*X***kv*0\*w...gU*...N*}*AN*9$K*|...
[ERR] Could not unmarshal interaction data interaction: server.Interaction.Protocol: ReadString: invalid control character found: 4, error found in #10 byte of ...|rotocol":"dns*j  ...|... , bigger context ...|{"protocol":"dns*j  *}_f*****Jf<...frb...y*5*|...
[ERR] Could not unmarshal interaction data interaction: server.Interaction.Protocol: ReadString: invalid control character found: 9, error found in #10 byte of ...|rotocol":"dns*,  *' |... , bigger context ...|{"protocol":"dns*,  *'c|}*r*0*}*u*8**}*U***:*}*z'*[****|...
[INF] Skipped bd.hilton.com:80 from target list as found unresponsive 31 times
[INF] Skipped beijing.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped china.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped bcm.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped alexandria.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped atlanta.hilton.com:80 from target list as found unresponsive 32 times
[INF] Skipped eugene.hilton.com:80 from target list as found unresponsive 32 times
[INF] Skipped excel.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped aaa.hilton.com:80 from target list as found unresponsive 31 times
[INF] Skipped families.hilton.com:80 from target list as found unresponsive 32 times
[INF] Skipped finance.hilton.com:80 from target list as found unresponsive 32 times
[INF] Skipped fonts.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped covid-origin.hilton.com:80 from target list as found unresponsive 31 times
[INF] Skipped careers.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped development.hilton.com:80 from target list as found unresponsive 30 times
[INF] Skipped amex.hilton.com:80 from target list as found unresponsive 31 times
[INF] Skipped gen.hilton.com:80 from target list as found unresponsive 31 times

```

7.2 Comprobar subdomain takeover (subzy sobre lista de subdominios)

Objetivo del paso

El objetivo de esta fase es identificar **posibles casos de subdomain takeover** dentro del scope (*.hilton.com). Se busca detectar subdominios que apunten (mediante **CNAME**) a servicios de terceros potencialmente **no configurados** o “huérfanos”, situación que, en determinados proveedores, puede permitir que un tercero reclame el recurso y tome control del subdominio. Este resultado sirve para:

- priorizar candidatos con señales de takeover,
- validar manualmente los positivos para descartar falsos positivos,
- y documentar evidencia reproducible (DNS + HTTP) de cada candidato.

Input utilizado

Se utilizó como entrada la lista consolidada de subdominios obtenida tras el footprinting:

- ~/recopilacion/hilton.com/06_targets/footprinting_subdomains_raw.txt

Instalación (Go) y disponibilidad de la herramienta

Durante la ejecución se detectó que **subzy** no estaba instalado (“command not found”). El repositorio original referenciado por el profesor cambió su “module path” (go.mod), por lo que la instalación correcta en Go se realizó usando el path actual del módulo:

- github.com/PentestPad/subzy@latest

La herramienta quedó disponible en el sistema para su ejecución desde terminal.

Ejecución (comando exacto utilizado)

Para asegurar que todo el output quedase registrado incluso en caso de errores HTTP, se ejecutó subzy capturando stdout/stderr y guardándolo en fichero:

- Output generado:
 - ~/recopilacion/hilton.com/08_vuln/subzy_raw.txt

Resultado obtenido (candidatos señalados por subzy)

En el output se identificaron dos subdominios marcados como potencialmente vulnerables por la herramienta:

- marketing.hilton.com [Cargo Collective]

- `pki.hilton.com` [Cargo Collective]

(El resto de entradas se clasificaron como **NOT VULNERABLE** o **HTTP ERROR** en función de la respuesta del target).

Validación mínima (DNS y HTTP) de los candidatos

Dado que las herramientas de takeover pueden producir falsos positivos, se realizó una validación básica en dos niveles:

1) DNS (CNAME)

Se comprobó el CNAME para ambos subdominios, observándose resolución hacia un endpoint de **S3 Website**:

- `s3-website-us-east-1.amazonaws.com`.

2) HTTP (respuesta y firma de proveedor)

Se revisó la respuesta HTTP para detectar señales típicas de recurso inexistente vs recurso existente:

- Para `pki.hilton.com` en **HTTP** se obtuvo respuesta con cabeceras de **AmazonS3** y el error:
 - `x-amz-error-code: NoSuchKey`
 - detalle: falta `index.html`
 - `Server: AmazonS3`

Este patrón indica que el servicio responde como S3 y que el recurso solicitado (objeto) no existe; no corresponde al patrón típico de bucket inexistente (**NoSuchBucket**), que sería el indicio fuerte de takeover.

- Para `marketing.hilton.com` se obtuvo una página HTML con **404 Not Found** genérico.

Output de validación guardado en:

- `~/recopilacion/hilton.com/08_vuln/subzy_takeover_http_check.txt`
- `~/recopilacion/hilton.com/08_vuln/pki_head_check.txt`

Control de calidad (QC)

- Input subzy: `06_targets/footprinting_subdomains_raw.txt`
- Output subzy: `08_vuln/subzy_raw.txt` (output completo, incluyendo **HTTP ERROR**, **NOT VULNERABLE** y positivos).

- Validación DNS: CNAME hacia `s3-website-us-east-1.amazonaws.com`.
- Validación HTTP:
 - `pki.hilton.com`: AmazonS3 + NoSuchKey
 - `marketing.hilton.com`: 404 Not Found genérico
- Outputs de validación: `subzy_takeover_http_check.txt` y `pki_head_check.txt`

Evidencia

```
(kali@kali)-[~]
$ cd ~/recopilacion/hilton.com 66 \
echo "=== 7.2 SUBZY (OUTPUT + POSITIVOS) ===" 66 \
ls -lah 08_vuln/subzy_raw.txt 08_vuln/subzy_takeover_http_check.txt 08_vuln/pki_head_check.txt 66 \
echo 66 \
grep -n "VULNERABLE" 08_vuln/subzy_raw.txt | grep -v "NOT VULNERABLE" 66 \
echo 66 \
echo "=== DNS (CNAME) ===" 66 \
dig +short CNAME marketing.hilton.com pki.hilton.com 66 \
echo 66 \
echo "=== HTTP VALIDATION (PKI) ===" 66 \
sed -n '1,20p' 08_vuln/pki_head_check.txt 66 \
echo 66 \
echo "=== HTTP VALIDATION (MARKETING) ===" 66 \
sed -n '1,20p' 08_vuln/subzy_takeover_http_check.txt
=== 7.2 SUBZY (OUTPUT + POSITIVOS) ===
-rw-rw-r-- 1 kali kali 411 Mar  8 05:01 08_vuln/pki_head_check.txt
-rw-rw-r-- 1 kali kali 43K Mar  8 04:50 08_vuln/subzy_raw.txt
-rw-rw-r-- 1 kali kali 501 Mar  8 05:00 08_vuln/subzy_takeover_http_check.txt

449:[ VULNERABLE ] - marketing.hilton.com [ Cargo Collective ]
555:[ VULNERABLE ] - pki.hilton.com [ Cargo Collective ]

=== DNS (CNAME) ===
s3-website-us-east-1.amazonaws.com.

=== HTTP VALIDATION (PKI) ===
### https://pki.hilton.com

### http://pki.hilton.com
HTTP/1.1 404 Not Found
x-amz-error-code: NoSuchKey
x-amz-error-message: The specified key does not exist.
x-amz-error-detail-Key: index.html
x-amz-request-id: DRHHKK654217WJJW
x-amz-id-2: u7/OLVJP8HZT7K0+T9GHastfVMMnBc4WHhuNExJA+d0ULUhSOR4EfWRfwLUalbqliNMtGlrXDbY=
Transfer-Encoding: chunked
Date: Sun, 08 Mar 2026 09:01:02 GMT
Server: AmazonS3

=== HTTP VALIDATION (MARKETING) ===
### marketing.hilton.com
<!DOCTYPE html>
<html>
<head>
<title>404 Not Found</title>
<link rel="stylesheet" href="/styles/status-code-error-page.css">
</head>
<body>
<div class="main">
<h1>404 Not Found</h1>
<p class="bold">
The resource you are looking for has been removed, had its name changed,
or is temporarily unavailable.
</p>
<p>We apologize for the inconvenience.</p>
</div>
</body>
</html>

### pki.hilton.com
```

Anexos generados (para el ZIP de outputs CLI)

- 08_vuln/subzy_raw.txt
- 08_vuln/subzy_takeover_http_check.txt
- 08_vuln/pki_head_check.txt

7.3 Análisis SSL/TLS — SSL Labs (dominio principal)

Objetivo del paso

El objetivo de esta fase es evaluar la postura criptográfica (TLS/SSL) del **dominio principal** mediante un informe externo estándar (Qualys SSL Labs), para identificar configuraciones que reduzcan el nivel de seguridad o compatibilidad, y dejar evidencia verificable. En concreto, se revisa: soporte de protocolos TLS, calidad del certificado y cadena, y controles de endurecimiento (p. ej., HSTS).

Ejecución

Se realizó el test en **SSL Labs (SSL Server Test)** sobre:

- Dominio evaluado: **hilton.com**
- IP evaluada por SSL Labs: **167.187.200.23**
- Fecha/hora de evaluación (según informe): **Sun, 08 Mar 2026 12:02:39 UTC**

El informe se guardó como PDF para anexos.

Resultados (datos relevantes del informe)

Calificación global

- **Overall Rating: B**

Motivos principales indicados por SSL Labs

- El servidor **soporta TLS 1.1**, lo que **limita la calificación a B** ("Grade capped to B").
- El servidor **no soporta TLS 1.3**.

HSTS

- SSL Labs indica que está desplegado **HSTS con duración larga**.

Certificado

- Certificado #1: **RSA 2048 bits (SHA256withRSA)**
- Emisor: **DigiCert Global G2 TLS RSA SHA256 2020 CA1**
- Validez: **29 Sep 2025 → 28 Sep 2026** (en el momento del informe, expira en ~6 meses)
- El informe refleja transparencia de certificado (**Certificate Transparency: Yes**).

Interpretación (para el informe)

La calificación **B** está determinada por decisiones de compatibilidad/seguridad: mantener **TLS 1.1** habilitado degrada la nota y **no disponer de TLS 1.3** indica que no se está ofreciendo el protocolo más moderno. Aun así, el certificado presentado es de **2048 bits RSA** con algoritmo de firma **SHA-256**, emitido por una CA pública reconocida (DigiCert), y el dominio presenta controles de endurecimiento como **HSTS**. La recomendación implícita del propio informe para mejorar la calificación sería **deshabilitar TLS 1.1** y **habilitar TLS 1.3** si la arquitectura lo permite.

Evidencia

HomeProjectsQualys Free TrialContact

You are here: [Home](#) > [Projects](#) > [SSL Server Test](#) > hilton.com

SSL Report: hilton.com (167.187.200.23)

Assessed on: Sun, 08 Mar 2026 12:02:39 UTC | [Hide](#) | [Clear cache](#)

[Scan Another »](#)

Summary

Overall Rating

Certificate	
Protocol Support	
Key Exchange	
Cipher Strength	

Visit our [documentation page](#) for more information, configuration guides, and books. Known issues are documented [here](#).

This server supports TLS 1.1. Grade capped to B. [MORE INFO »](#)

This server does not support TLS 1.3. [MORE INFO »](#)

HTTP Strict Transport Security (HSTS) with long duration deployed on this server. [MORE INFO »](#)

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject

hilton.com

Fingerprint SHA256: e8f36b5d11509b24aa5cb7a1f8f5e70e9106ceb44d8d572df50ecb3ac60f8ce1

Pin SHA256: KDubxbh6FtVEvrxDR4s/WufO0eiYHuOF0b7MUDRW0uE=

Common names

hilton.com

Alternative names

hilton.com

Serial Number

0abd6a591b74dd7cfa368d7cb0b5eb7e

Valid from

Mon, 29 Sep 2025 00:00:00 UTC

Valid until

Mon, 28 Sep 2026 23:59:59 UTC (expires in 6 months and 20 days)

Key

RSA 2048 bits (e 65537)

Weak key (Debian)

No

Issuer	DigiCert Global G2 TLS RSA SHA256 2020 CA1 AJA: http://cacerts.digicert.com/DigiCertGlobalG2TLRSASHA2562020CA1-1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl3.digicert.com/DigiCertGlobalG2TLRSASHA2562020CA1-1.crl OCSP: http://ocsp.digicert.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows



Additional Certificates (if supplied)



Certificates provided	2 (2987 bytes)
Chain issues	None

#2

Subject	DigiCert Global G2 TLS RSA SHA256 2020 CA1 Fingerprint SHA256: c8025f9fc65dfc95b3ca8cc7867b9a587b5277973957917463fc813d0b625a9 Pin SHA256: Wec45nQIFwKvHtuHxSAMGkt19k+uPSw9JIEkxhvYPHk=
Valid until	Sat, 29 Mar 2031 23:59:59 UTC (expires in 5 years)
Key	RSA 2048 bits (e 65537)
Issuer	DigiCert Global Root G2
Signature algorithm	SHA256withRSA



Certification Paths



Mozilla Apple Android Java Windows

Path #1: Trusted



1	Sent by server	hilton.com Fingerprint SHA256: e8f36b5d11509b24aa5cb7a1f8f5e70e9106ceb44d8d572df50ecb3ac60f8ce1 Pin SHA256: KDubxh6FtVEvpxDR4s/W/ufO0eIYHuOF0b7MUDRWOUe= RSA 2048 bits (e 65537) / SHA256withRSA
2	Sent by server	DigiCert Global G2 TLS RSA SHA256 2020 CA1 Fingerprint SHA256: c8025f9fc65dfc95b3ca8cc7867b9a587b5277973957917463fc813d0b625a9 Pin SHA256: Wec45nQIFwKvHtuHxSAMGkt19k+uPSw9JIEkxhvYPHk= RSA 2048 bits (e 65537) / SHA256withRSA
3	In trust store	DigiCert Global Root G2 Self-signed Fingerprint SHA256: cb3ccbb76031e5e0138f8dd39a23f9de47ffc35e43c1144cea27d46a5ab1cb5f Pin SHA256: i7WTqTvh0OiolnulfFR4kMPnBqrS2rdIVPl/s2uC/CY= RSA 2048 bits (e 65537) / SHA256withRSA

Configuration



Protocols

TLS 1.3	No
TLS 1.2	Yes
TLS 1.1	Yes
TLS 1.0	No
SSL 3	No
SSL 2	No



Cipher Suites

# TLS 1.2 (suites in server-preferred order)		
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	WEAK	128
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	WEAK	128
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)	WEAK	128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)	WEAK	256
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	WEAK	256
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)	WEAK	256
TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (0x41)	WEAK	128
TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (0x84)	WEAK	256
# TLS 1.1 (suites in server-preferred order)		



Handshake Simulation

Android 4.4.2	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 5.0.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 6.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 7.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 8.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 8.1	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Android 9.0	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS

BingPreview Jan 2015	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Chrome 49 / XP SP3	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Chrome 69 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Chrome 70 / Win 10	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Chrome 80 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Firefox 31.3.0 ESR / Win 7	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Firefox 47 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Firefox 49 / XP SP3	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Firefox 62 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Firefox 73 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Googlebot Feb 2018	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
IE 11 / Win 7 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
IE 11 / Win 8.1 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
IE 11 / Win Phone 8.1 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
IE 11 / Win Phone 8.1 Update R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
IE 11 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Edge 15 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Edge 16 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Edge 18 / Win 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Edge 13 / Win Phone 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Java 8u161	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Java 11.0.3	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Java 12.0.1	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
OpenSSL 1.0.1l R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
OpenSSL 1.0.2s R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
OpenSSL 1.1.0k R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
OpenSSL 1.1.1c R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 6 / iOS 6.0.1	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
Safari 7 / iOS 7.1 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
Safari 7 / OS X 10.9 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
Safari 8 / iOS 8.4 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
Safari 8 / OS X 10.10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	ECDH secp256r1	FS
Safari 9 / iOS 9 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 9 / OS X 10.11 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 10 / iOS 10 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 10 / OS X 10.12 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 12.1.2 / MacOS 10.14.6 Beta R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Safari 12.1.1 / iOS 12.3.1 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Apple ATS 9 / iOS 9 R	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS
Yahoo Slurp Jan 2015	RSA 2048 (SHA256)	TLS 1.2	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	ECDH secp256r1	FS

YandexBot Jan 2015

RSA 2048 (SHA256)

TLS 1.2

TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256

ECDH secp256r1

FS

Not simulated clients (Protocol mismatch)

[Click here to expand](#)

(1) Clients that do not support Forward Secrecy (FS) are excluded when determining support for it.

(2) No support for virtual SSL hosting (SNI). Connects to the default site if the server uses SNI.

(3) Only first connection attempt simulated. Browsers sometimes retry with a lower protocol version.

(R) Denotes a reference browser or client, with which we expect better effective security.

(All) We use defaults, but some platforms do not use their best protocols and features (e.g., Java 6 & 7, older IE).

(All) Certificate trust is not checked in handshake simulation, we only perform TLS handshake.



Protocol Details

Secure Renegotiation	Supported
Secure Client-Initiated Renegotiation	Yes
Insecure Client-Initiated Renegotiation	No
BEAST attack	Mitigated server-side (more info)
POODLE (SSLv3)	No, SSL 3 not supported (more info)
POODLE (TLS)	No (more info)
Zombie POODLE	No (more info) TLS 1.2 : 0xc013
GOLDENDOODLE	No (more info) TLS 1.2 : 0xc013
OpenSSL 0-Length	No (more info) TLS 1.2 : 0xc013
Sleeping POODLE	No (more info) TLS 1.2 : 0xc013
Downgrade attack prevention	Yes, TLS_FALLBACK_SCSV supported (more info)
SSL/TLS compression	No
RC4	No
Heartbeat (extension)	No
Heartbleed (vulnerability)	No (more info)
Ticketbleed (vulnerability)	No (more info)
OpenSSL CCS vuln. (CVE-2014-0224)	No (more info)
OpenSSL Padding Oracle vuln. (CVE-2016-2107)	No (more info)
ROBOT (vulnerability)	No (more info)
Forward Secrecy	Yes (with most browsers) ROBUST (more info)
ALPN	No
NPN	No
Session resumption (caching)	Yes
Session resumption (tickets)	No
OCSP stapling	No

Strict Transport Security (HSTS)**Yes**

max-age=16070400; includeSubDomains

HSTS Preloading

Not in: Chrome Edge Firefox IE

Public Key Pinning (HPKP)

No ([more info](#))

Public Key Pinning Report-Only

No

Public Key Pinning (Static)

No ([more info](#))

Long handshake intolerance

No

TLS extension intolerance

No

TLS version intolerance

No

Incorrect SNI alerts

No

Uses common DH primes

No, DHE suites not supported

DH public server param (Ys) reuse

No, DHE suites not supported

ECDH public server param reuse

No

Supported Named Groups

secp256r1, x25519, secp384r1 (server preferred order)

SSL 2 handshake compatibility

Yes

**HTTP Requests****1** <https://hilton.com/> (HTTP/1.1 301 Moved Permanently)**Miscellaneous****Test date** Sun, 08 Mar 2026 12:01:02 UTC**Test duration** 97.436 seconds**HTTP status code** 301**HTTP forwarding** <https://www.hilton.com>**HTTP server signature** Apache**Server hostname** ftcbo.hilton.com

SSL Report v2.4.1

Anexos generados

- [99_anexos/07_3_SSL_Labs_hilton.com_2026-03-08.pdf](#)

7.4 Análisis DMARC/SPF/DKIM — dmarcian domain checker (dominio principal)

Objetivo del paso

El objetivo de esta fase es evaluar la configuración de autenticación de correo del dominio principal (hilton.com) mediante el **domain checker de dmarcian**, con el fin de identificar el nivel de protección frente a **suplantación (email spoofing)** y el grado de aplicación de políticas de autenticación. Este análisis permite:

- confirmar si existe un registro **DMARC** válido y su política (**p=**),
- validar si el dominio publica un **SPF** válido y si aplica “hard fail” (**-all**),
- verificar la presencia de **DKIM** (al menos un registro/selector válido),
- y documentar oportunidades de endurecimiento (por ejemplo, pasar de **quarantine** a **reject** si procede).

Ejecución

Se ejecutó el análisis en el servicio **dmarcian – Domain Checker** para:

- Dominio evaluado: hilton.com

El resultado se guardó en PDF y se incorporó a anexos.

Resultados obtenidos (según dmarcian)

1) DMARC

El dominio presenta un registro DMARC **válido** y, según el checker, está configurado con política:

- **p=quarantine**

El checker indica que, para aprovechar DMARC al máximo, la política podría endurecerse a:

- **p=reject**

Detalles del registro (tal como aparece en el resultado):

- `v=DMARC1; p=quarantine; fo=1; rua=mailto:dmarc_rua@hilton.com; ruf=mailto:dmarc_ruf@hilton.com`

Interpretación técnica:

- `p=quarantine` implica que los mensajes que **fallen DMARC** (alineación y/o validación SPF/DKIM según aplique) deben tratarse como sospechosos (habitualmente enviados a spam/cuarentena por el receptor). Es una política efectiva pero menos estricta que `reject`.
- `fo=1` solicita reportes forenses cuando **falle DKIM o SPF** (si el receptor soporta este tipo de reportes).
- `rua=...` define el buzón de **reportes agregados** (RUA), útiles para visibilidad y monitorización de fuentes de envío.
- `ruf=...` define el buzón de **reportes forenses** (RUF), cuando el receptor los emite (cada vez menos comunes por privacidad/soporte).

2) SPF

El checker indica que el dominio tiene un SPF **válido** y que especifica un **hard fail**:

- `-all`

Detalles del registro SPF (tal como aparece en el resultado):

- `v=spf1 include:spf.protection.outlook.com include:_spf-a.hilton.com include:_spf-b.hilton.com include:_spf-c.hilton.com -all`

Interpretación técnica:

- `v=spf1` define el inicio del registro SPF.
- Los `include:` delegan la autorización de envío a:
 - `spf.protection.outlook.com` (típico de infraestructura Microsoft 365/Exchange Online),
 - y a varios sub-registros internos (`_spf-a`, `_spf-b`, `_spf-c`) que permiten segmentar fuentes autorizadas (por ejemplo, distintos sistemas o proveedores de envío).
- `-all` significa **hard fail**: cualquier servidor que no esté autorizado por las reglas anteriores debería fallar SPF, lo que fortalece la protección frente a spoofing (especialmente si DMARC está aplicado).

3) DKIM

El checker indica que se encontró **al menos un DKIM válido** para el dominio.

Interpretación técnica:

- La existencia de DKIM válido indica que al menos una fuente de envío firma el correo con DKIM usando claves publicadas en DNS.
- Es normal que existan múltiples selectores/keys para distintas plataformas (correo corporativo, marketing, automatizaciones, etc.); el checker confirma que **al menos uno** está correctamente publicado.

Interpretación global (riesgo y postura)

La combinación observada (DMARC válido con **p=quarantine**, SPF válido con **-all**, y DKIM presente) refleja una postura **robusta** frente a suplantación de correo. El punto de mejora señalado por la propia herramienta es el paso de **p=quarantine** a **p=reject**, que incrementa la aplicación de DMARC al bloquear de forma más estricta los envíos no alineados o no autenticados. En un contexto corporativo amplio, el cambio a **reject** suele requerir haber monitorizado previamente los reportes RUA para evitar falsos positivos sobre fuentes legítimas.

Evidencia: (capturas zqui)

DMARC

Your domain has a valid DMARC record and it is set to p=quarantine. To fully take advantage of DMARC, the policy should be set to p=reject.

— Details

```
v=DMARC1;p=quarantine;fo=1;rua=mailto:dmarc_rua@hilton.com;ruf=mailto:dmarc_ruf@hilton.com
```

To understand and fix the specific errors, use our [DMARC Inspector](#).

SPF

Great job! You have a valid SPF record, which specifies a hard fail (-all).

— Details

```
v=spf1 include:spf.protection.outlook.com include:_spf-a.hilton.com include:_spf-b.hilton.com include:_spf-c.hilton.com -all
```

To understand and fix the specific errors, use our [SPF Surveyor](#).

DKIM

We found at least one DKIM valid record. It's likely that you have others as each email sending source should have its own DKIM keys. DMARC visibility can help you discover each of your DKIM keys and much more.

— Details

```
v=DKIM1; k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAvIR5SLtVvsU2c46scwrUfpw25/h9Zl0Ms3ctvwnniLXYM2lvx0Zpz6W6tAhNhZKPQRElLRJE
ar80iH7P00FZCwofoTJgkJe6RpKfeUFZj85NF5y08BRd3jo0kM9bbgIf80C+yjc4IrzhL9D8FxeF0dEail0Uvr00m+bPTpZlcVvyhv3WdrwrDiK00U+IZlp
0F9lghU0SfrSiFP6xeuCnCCHR3ziUsqrBuMIfeMe8X36tX6G3+1+WkQ+SRM5jSBaYdBe+FrBbjenPUzEhteZa360wesES2Z9tM06dxbXfvJSQDxtgBo4Fv
IOPC+R65j9ZGEB7uXNe3tcM4ehyrpwQIDAQAB;
```

For more information about your DKIM record we recommend our [DKIM Inspector](#).

Anexos generados

- [99_anexos/07_4_DMARC_dmarcian_hilton.com_2026-03-08.pdf](#)

8. OSINT

8.1 Identificación inicial de empleados relevantes y análisis de presencia en redes mediante Sherlock

Objetivo del paso

El objetivo de esta subfase fue iniciar la recogida de información pública sobre personal relevante vinculado a Hilton, priorizando perfiles con interés corporativo para el reconocimiento, tales como cargos ejecutivos, financieros, tecnológicos, comerciales y de recursos humanos. De forma complementaria, se aplicó una herramienta de análisis de presencia en redes sociales para comprobar si alguno de esos perfiles reutilizaba identificadores públicos en distintas plataformas, lo que puede aportar contexto adicional sobre exposición digital y reutilización de nombres de usuario.

Ejecución

En primer lugar, se realizó una localización manual de empleados y directivos relevantes mediante fuentes públicas, principalmente perfiles profesionales accesibles desde LinkedIn y directorios corporativos indexados por buscadores. A partir de esa fase inicial se consolidó un listado de personas de interés asociadas a Hilton, incluyendo perfiles ejecutivos y responsables de áreas sensibles o estratégicas.

Posteriormente, para acelerar la verificación de exposición pública en servicios y plataformas, se utilizó la herramienta **Sherlock** sobre uno de los identificadores más claros obtenidos durante la fase manual: **chrisnassetta**, correspondiente al perfil profesional del CEO de Hilton. La salida completa de la herramienta se almacenó como evidencia bruta y, adicionalmente, se generó una versión filtrada con los resultados más representativos y útiles para análisis.

Resultados obtenidos

La fase manual permitió reunir una primera base de empleados relevantes de Hilton, entre ellos cargos de dirección ejecutiva, finanzas, tecnología, recursos humanos, desarrollo y marketing. Esta selección se consideró suficiente para arrancar la fase OSINT con una muestra de perfiles corporativos con valor para el reconocimiento.

En la comprobación mediante Sherlock sobre el identificador **chrisnassetta**, la herramienta devolvió múltiples coincidencias en distintas plataformas públicas. Entre los resultados obtenidos, destacó especialmente la coincidencia en **LinkedIn**, al tratarse de un perfil atribuible y coherente con la identidad profesional ya localizada previamente. Además, aparecieron coincidencias en otros servicios y plataformas, tales como Archive.org, GeeksforGeeks, Hashnode, Letterboxd, Spotify, Steam, Strava, TryHackMe y YouTube. Estos hallazgos fueron conservados como evidencia, aunque no todos pueden atribuirse automáticamente a la misma persona sin validación adicional.

Interpretación técnica

Desde una perspectiva OSINT, el resultado relevante de esta subfase no es únicamente la existencia de un perfil profesional en LinkedIn, sino la **reutilización potencial de un mismo identificador** en múltiples plataformas públicas. Este patrón puede ser útil en tareas de correlación de identidad digital, ya que permite

rastrear de forma más eficiente cuentas, servicios o huellas públicas asociadas a un mismo nombre de usuario.

No obstante, conviene interpretar estos resultados con prudencia. Herramientas como Sherlock identifican coincidencias de username, pero eso no equivale por sí mismo a una atribución concluyente. En otras palabras, que el identificador **chrisnassetta** exista en varias plataformas no implica automáticamente que todas esas cuentas pertenezcan al CEO de Hilton. La atribución fiable exige validación contextual adicional, por ejemplo mediante fotografías, biografías, enlaces cruzados, actividad pública coherente o referencias directas al entorno profesional de la persona.

Por tanto, dentro del informe, este hallazgo debe presentarse como una **detección de presencia pública y posible reutilización de identificador**, no como una atribución total de identidad sobre todas las plataformas listadas.

Interpretación global

Esta subfase permitió establecer una base inicial sólida para el apartado 5.1, combinando dos enfoques complementarios. Por un lado, la identificación manual de empleados relevantes aportó contexto corporativo y orientó la investigación hacia perfiles con mayor interés desde el punto de vista de reconocimiento. Por otro, la aplicación de Sherlock permitió demostrar de forma práctica cómo un identificador público asociado a uno de esos perfiles puede aparecer replicado en múltiples servicios, generando nuevas líneas de investigación OSINT.

El resultado es útil como evidencia metodológica de que la fase de OSINT no se limita a recopilar nombres y cargos, sino que también busca evaluar la exposición pública asociada a identidades corporativas relevantes, siempre manteniendo una interpretación prudente y técnicamente correcta de los hallazgos.

Evidencia

```
(kali@kali)-[~/recopilacion/hilton.com]
$ cat ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_raw.txt
Update available! 0.15.0 → 0.16.0
https://github.com/sherlock-project/sherlock/releases/tag/v0.16.0
[*] Checking username chrisnassetta on:

[+] Archive.org: https://archive.org/details/@chrisnassetta
[+] Code Snippet Wiki: https://codesnippets.fandom.com/wiki/User:chrisnassetta
[+] Codolio: https://codolio.com/profile/chrisnassetta
[+] Envato Forum: https://forums.envato.com/u/chrisnassetta
[+] GNOME VCS: https://gitlab.gnome.org/chrisnassetta
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/chrisnassetta
[+] HackenProof (Hackers): https://hackenproof.com/hackers/chrisnassetta
[+] Hashnode: https://hashnode.com/@chrisnassetta
[+] Hubski: https://hubski.com/user/chrisnassetta
[+] LessWrong: https://www.lesswrong.com/users/chrisnassetta
[+] Letterboxd: https://letterboxd.com/chrisnassetta
[+] LibraryThing: https://www.librarything.com/profile/chrisnassetta
[+] LinkedIn: https://linkedin.com/in/chrisnassetta
[+] NationStates Nation: https://nationstates.net/nation=chrisnassetta
[+] NationStates Region: https://nationstates.net/region=chrisnassetta
[+] Patched: https://patched.sh/User/chrisnassetta
[+] Rarible: https://rarible.com/marketplace/api/v4/urls/chrisnassetta
[+] Roblox: https://www.roblox.com/user.aspx?username=chrisnassetta
[+] Shelf: https://www.shelf.im/chrisnassetta
[+] Slashdot: https://slashdot.org/~chrisnassetta
[+] SlideShare: https://slideshare.net/chrisnassetta
[+] Splice: https://splice.com/chrisnassetta
[+] Spotify: https://open.spotify.com/user/chrisnassetta
[+] Steam Community (Group): https://steamcommunity.com/groups/chrisnassetta
[+] Steam Community (User): https://steamcommunity.com/id/chrisnassetta/
[+] Strava: https://www.strava.com/athletes/chrisnassetta
[+] TryHackMe: https://tryhackme.com/p/chrisnassetta
[+] Weblate: https://hosted.weblate.org/user/chrisnassetta/
[+] YandexMusic: https://music.yandex/users/chrisnassetta/playlists
[+] YouTube: https://www.youtube.com/@chrisnassetta
[+] mercadolibre: https://www.mercadolibre.com.br/perfil/chrisnassetta
[+] phpRU: https://php.ru/forum/members/?username=chrisnassetta
[+] svidbook: https://www.svidbook.ru/user/chrisnassetta

[*] Search completed with 33 results

(kali@kali)-[~/recopilacion/hilton.com]
$ grep -E "LinkedIn|TryHackMe|YouTube|Archive.org|Hashnode|GeeksforGeeks|Letterboxd|Spotify|Steam|Strava" ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_raw.txt > ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_filtered.txt

(kali@kali)-[~/recopilacion/hilton.com]
$ cat ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_filtered.txt
[+] Archive.org: https://archive.org/details/@chrisnassetta
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/chrisnassetta
[+] Hashnode: https://hashnode.com/@chrisnassetta
[+] Letterboxd: https://letterboxd.com/chrisnassetta
[+] LinkedIn: https://linkedin.com/in/chrisnassetta
[+] Spotify: https://open.spotify.com/user/chrisnassetta
[+] Steam Community (Group): https://steamcommunity.com/groups/chrisnassetta
[+] Steam Community (User): https://steamcommunity.com/id/chrisnassetta/
[+] Strava: https://www.strava.com/athletes/chrisnassetta
[+] TryHackMe: https://tryhackme.com/p/chrisnassetta
[+] YouTube: https://www.youtube.com/@chrisnassetta
```

Anexos generados

- 09_osint/empleados_emails_raw.txt
- 09_osint/sherlock_chrisnassetta_raw.txt
- 09_osint/sherlock_chrisnassetta_filtered.txt
- 09_osint/sherlock_chrisnassetta/

8.2 Localización de emails de empleados, empleados relevantes y comprobación de data breaches

Objetivo del paso

El objetivo de esta fase fue identificar empleados relevantes vinculados a Hilton y localizar al menos una dirección de correo corporativo válida para comprobar su posible exposición en brechas de datos públicas mediante HavelBeenPwned. El análisis se centró en perfiles con interés corporativo, como cargos ejecutivos, financieros, tecnológicos, comerciales y de recursos humanos.

Ejecución

En primer lugar, se realizó una búsqueda manual de empleados relevantes asociados a Hilton mediante fuentes públicas accesibles desde buscadores y perfiles profesionales indexados. A partir de esa revisión se recopiló una primera muestra de perfiles corporativos de interés.

Como apoyo a la fase manual, se utilizó la herramienta **Sherlock** sobre el identificador **chrisnassetta**, correspondiente al perfil profesional del CEO de Hilton, con el objetivo de detectar si dicho username aparecía reutilizado en múltiples plataformas públicas.

Posteriormente, se localizó un correo corporativo público, **Analía.Castaldi@Hilton.com**, y se comprobó en **HavelBeenPwned** para verificar si aparecía asociado a brechas de datos conocidas públicamente.

Resultados obtenidos

La búsqueda manual permitió identificar varios empleados y perfiles relevantes asociados a Hilton, incluyendo cargos ejecutivos, comerciales, financieros, tecnológicos y de recursos humanos.

La ejecución de Sherlock sobre **chrisnassetta** devolvió múltiples coincidencias en distintas plataformas. Entre ellas, la coincidencia más relevante fue **LinkedIn**, al ser coherente con la identidad profesional ya localizada. El resto de plataformas encontradas se conservaron como hallazgos de posible reutilización del identificador, aunque sin atribución concluyente.

En la búsqueda de correos corporativos se localizó la dirección **Analía.Castaldi@Hilton.com**. La comprobación posterior en **HavelBeenPwned** devolvió un resultado de **0 brechas**, por lo que no se detectó exposición pública conocida para esa cuenta en el momento del análisis.

Interpretación técnica

Desde el punto de vista OSINT, la identificación de empleados relevantes permite orientar el reconocimiento hacia perfiles con mayor valor organizativo y potencial interés en campañas de suplantación, ingeniería social o análisis de exposición pública.

El uso de Sherlock permitió documentar un caso de **posible reutilización de username** en distintas plataformas. No obstante, este tipo de resultado debe interpretarse con cautela, ya que la coincidencia de nombre de usuario no implica por sí sola una atribución confirmada en todos los servicios detectados.

Respecto al correo corporativo localizado, el resultado de **0 brechas** en HavelBeenPwned indica que no existe exposición pública conocida de esa dirección en la fuente consultada, aunque ello no garantiza de forma absoluta la ausencia de filtraciones en otras bases o fuentes no indexadas.

Interpretación global

Esta fase permitió cumplir el objetivo del apartado, ya que se identificaron empleados relevantes de Hilton, se aplicó una herramienta de análisis de presencia en redes y se localizó un correo corporativo real que fue comprobado en una fuente pública de brechas. El resultado obtenido no evidenció compromiso conocido del correo analizado, pero sí dejó una base útil de perfiles y hallazgos para continuar la fase OSINT del ejercicio.

Evidencia

```
(kali@kali)~[/recopilacion/hilton.com]
$ cat ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_raw.txt
Update available! 0.15.0 → 0.16.0
https://github.com/sherlock-project/sherlock/releases/tag/v0.16.0
[*] Checking username chrisnassetta on:

[+] Archive.org: https://archive.org/details/@chrisnassetta
[+] Code Snippet Wiki: https://codesnippets.fandom.com/wiki/User:chrisnassetta
[+] Codolio: https://codolio.com/profile/chrisnassetta
[+] Envato Forum: https://forums.envato.com/u/chrisnassetta
[+] GNOME VCS: https://gitlab.gnome.org/chrisnassetta
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/chrisnassetta
[+] HackenProof (Hackers): https://hackenproof.com/hackers/chrisnassetta
[+] Hashnode: https://hashnode.com/@chrisnassetta
[+] Hubski: https://hubski.com/user/chrisnassetta
[+] LessWrong: https://www.lesswrong.com/users/chrisnassetta
[+] Letterboxd: https://letterboxd.com/chrisnassetta
[+] LibraryThing: https://www.librarything.com/profile/chrisnassetta
[+] LinkedIn: https://linkedin.com/in/chrisnassetta
[+] NationStates Nation: https://nationstates.net/nation=chrisnassetta
[+] NationStates Region: https://nationstates.net/region=chrisnassetta
[+] Patched: https://patched.sh/User/chrisnassetta
[+] Rarible: https://rarible.com/marketplace/api/v4/urls/chrisnassetta
[+] Roblox: https://www.roblox.com/user.aspx?username=chrisnassetta
[+] Shelf: https://www.shelf.im/chrisnassetta
[+] Slashdot: https://slashdot.org/~chrisnassetta
[+] SlideShare: https://slideshare.net/chrisnassetta
[+] Splice: https://splice.com/chrisnassetta
[+] Spotify: https://open.spotify.com/user/chrisnassetta
[+] Steam Community (Group): https://steamcommunity.com/groups/chrisnassetta
[+] Steam Community (User): https://steamcommunity.com/id/chrisnassetta/
[+] Strava: https://www.strava.com/athletes/chrisnassetta
[+] TryHackMe: https://tryhackme.com/p/chrisnassetta
[+] Weblate: https://hosted.weblate.org/user/chrisnassetta/
[+] YandexMusic: https://music.yandex/users/chrisnassetta/playlists
[+] YouTube: https://www.youtube.com/@chrisnassetta
[+] mercadolibre: https://www.mercadolibre.com.br/perfil/chrisnassetta
[+] phpRU: https://php.ru/forum/members/?username=chrisnassetta
[+] svidbook: https://www.svidbook.ru/user/chrisnassetta

[*] Search completed with 33 results

(kali@kali)~[/recopilacion/hilton.com]
$ grep -E "LinkedIn|TryHackMe|YouTube|Archive.org|Hashnode|GeeksforGeeks|Letterboxd|Spotify|Steam|Strava" ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_raw.txt > ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_filtered.txt

(kali@kali)~[/recopilacion/hilton.com]
$ cat ~/recopilacion/hilton.com/09_osint/sherlock_chrisnassetta_filtered.txt
[+] Archive.org: https://archive.org/details/@chrisnassetta
[+] GeeksforGeeks: https://auth.geeksforgeeks.org/user/chrisnassetta
[+] Hashnode: https://hashnode.com/@chrisnassetta
[+] Letterboxd: https://letterboxd.com/chrisnassetta
[+] LinkedIn: https://linkedin.com/in/chrisnassetta
[+] Spotify: https://open.spotify.com/user/chrisnassetta
[+] Steam Community (Group): https://steamcommunity.com/groups/chrisnassetta
[+] Steam Community (User): https://steamcommunity.com/id/chrisnassetta/
[+] Strava: https://www.strava.com/athletes/chrisnassetta
[+] TryHackMe: https://tryhackme.com/p/chrisnassetta
[+] YouTube: https://www.youtube.com/@chrisnassetta
```

Anexos generados

- 09_osint/empleados_emails_raw.txt
- 09_osint/sherlock_chrisnassetta_raw.txt
- 09_osint/sherlock_chrisnassetta_filtered.txt
- 09_osint/sherlock_chrisnassetta/

8.3 Extracción de metadatos

Objetivo del paso

El objetivo de esta fase fue analizar los metadatos de un documento público asociado a Hilton para identificar información técnica útil desde la perspectiva OSINT, como fechas de creación y modificación, versión del documento, herramienta de metadatos utilizada y posibles identificadores internos del archivo.

Ejecución

En primer lugar, se creó una carpeta específica para el análisis de metadatos dentro del apartado OSINT. Posteriormente, se localizó un documento PDF público accesible desde infraestructura asociada a Hilton y se descargó para su análisis local. El fichero seleccionado fue **HILTON-WORLDWIDE-INC_10K_2023_V1.pdf**, obtenido desde el subdominio **stories-editor.hilton.com**.

Una vez descargado el archivo, se utilizó **exiftool** para extraer sus metadatos. La salida completa se guardó como evidencia bruta y, adicionalmente, se generó una versión filtrada con los campos más relevantes para el informe.

Resultados obtenidos

El análisis confirmó que el fichero estudiado era un documento **PDF** de versión **1.7**, con un total de **120 páginas** y tipo MIME **application/pdf**.

En los metadatos se identificó el uso de **Adobe XMP Core 5.6-c016** como toolkit de metadatos. También se recuperaron varias marcas temporales relevantes, entre ellas la fecha de creación del documento, la fecha de modificación y la fecha de metadatos. Además, se obtuvieron identificadores únicos del archivo, concretamente un **Document ID** y un **Instance ID**, ambos expresados en formato UUID.

Interpretación técnica

Desde el punto de vista OSINT, los metadatos de documentos públicos pueden aportar información contextual útil sobre el ciclo de vida de un archivo y sobre las herramientas empleadas en su generación o edición. En este caso, la presencia de campos temporales permite situar cronológicamente la creación y modificación del documento, mientras que la presencia del toolkit XMP indica el uso de una cadena de procesamiento compatible con tecnología Adobe.

La existencia de identificadores únicos como **Document ID** e **Instance ID** no implica por sí sola una exposición crítica, pero sí demuestra que el documento conserva metadatos técnicos internos que pueden ser útiles para correlación documental, control de versiones o análisis comparativo con otros ficheros públicos de la organización.

No se identificaron en esta muestra nombres de usuario, autores explícitos, rutas locales, nombres de estaciones de trabajo ni otra información personal evidente. Por tanto, el documento no expone metadatos sensibles de alto impacto, aunque sí conserva información técnica estructural relevante para tareas de reconocimiento.

Interpretación global

La extracción de metadatos permitió comprobar que un documento público de Hilton conserva información técnica accesible desde fuentes abiertas. Aunque los metadatos encontrados no revelan datos personales directos ni elementos claramente sensibles, sí aportan contexto sobre la estructura del documento, su cronología y ciertos identificadores internos. En un ejercicio de reconocimiento, este tipo de análisis resulta útil porque permite ampliar la visibilidad sobre los activos documentales expuestos públicamente y evaluar si la organización publica archivos con exceso de metadatos.

Evidencia

```
(kali@kali)-[~/hilton.com/09_osint/metadatos/docs]
$ exiftool ~/recopilacion/hilton.com/09_osint/metadatos/docs/HILTON-WORLDWIDE-INC_10K_2023_V1.pdf | tee ~/recopilacion/hilton.com/09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1.txt
ExifTool Version Number      : 13.50
File Name                    : HILTON-WORLDWIDE-INC_10K_2023_V1.pdf
Directory                    : /home/kali/recopilacion/hilton.com/09_osint/metadatos/docs
File Size                     : 1759 kB
File Modification Date/Time   : 2023:04:04 16:01:29-04:00
File Access Date/Time        : 2026:03:08 11:14:42-04:00
File Inode Change Date/Time   : 2026:03:08 11:14:42-04:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                   : 1.7
Linearized                   : No
Has XFA                      : No
Page Count                   : 120
Page Layout                  : TwoPageRight
XMP Toolkit                   : Adobe XMP Core 5.6-c016 91.163616, 2018/10/29-16:58:49
Modify Date                  : 2023:04:03 12:10:55-05:00
Create Date                  : 2023:03:24 15:45:07-04:00
Metadata Date                : 2023:03:24 16:06:16-04:00
Format                       : application/pdf
Document ID                  : uuid:729766b8-be6f-479c-88dc-809ac0d3b25f
Instance ID                  : uuid:0525c83c-8929-4d0b-b24d-211815cc4161

(kali@kali)-[~/hilton.com/09_osint/metadatos/docs]
$ grep -E "File Name|File Type|MIME Type|PDF Version|Page Count|XMP Toolkit|Modify Date|Create Date|Metadata Date|Document ID|Instance ID" ~/recopilacion/hilton.com/09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1.txt > ~/recopilacion/hilton.com/09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1_filtered.txt

(kali@kali)-[~/hilton.com/09_osint/metadatos/docs]
$ cat ~/recopilacion/hilton.com/09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1_filtered.txt
File Name                    : HILTON-WORLDWIDE-INC_10K_2023_V1.pdf
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                   : 1.7
Page Count                   : 120
XMP Toolkit                   : Adobe XMP Core 5.6-c016 91.163616, 2018/10/29-16:58:49
Modify Date                  : 2023:04:03 12:10:55-05:00
Create Date                  : 2023:03:24 15:45:07-04:00
Metadata Date                : 2023:03:24 16:06:16-04:00
Document ID                  : uuid:729766b8-be6f-479c-88dc-809ac0d3b25f
Instance ID                  : uuid:0525c83c-8929-4d0b-b24d-211815cc4161
```

Anexos generados

- 09_osint/metadatos/docs/HILTON-WORLDWIDE-INC_10K_2023_V1.pdf
- 09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1.txt
- 09_osint/metadatos/exiftool_HILTON-WORLDWIDE-INC_10K_2023_V1_filtered.txt

8.4 Análisis de redes sociales — comprobación de username con WhatsMyName y limitación operativa en CheckUser

Objetivo del paso

El objetivo de esta subfase fue comprobar si el identificador **chrisnassetta**, previamente asociado a un perfil relevante de Hilton, aparecía reutilizado en redes sociales y servicios públicos mediante herramientas específicas de búsqueda de usernames. Para ello se utilizaron dos fuentes distintas: **WhatsMyName** y **CheckUser**, con la finalidad de contrastar la presencia pública del identificador en plataformas sociales y servicios online.

Ejecución

En primer lugar, se utilizó la herramienta web **WhatsMyName** introduciendo el username **chrisnassetta**. El propósito fue verificar si la plataforma detectaba coincidencias automáticas del identificador en su conjunto de sitios soportados.

Posteriormente, se intentó realizar la misma comprobación en **CheckUser** con el mismo username. Sin embargo, durante la ejecución de esta segunda herramienta no fue posible completar la búsqueda, ya que el servicio devolvió un error vinculado al mecanismo **CAPTCHA**, incluso tras la validación manual de “no soy un robot”.

Resultados obtenidos

En **WhatsMyName**, la comprobación del username **chrisnassetta** devolvió un resultado principal de **Found: 0**, por lo que la herramienta no confirmó coincidencias automáticas del identificador en su tabla principal de resultados.

No obstante, en la parte inferior de la interfaz se mostraron resultados auxiliares de búsqueda documental y web relacionados con el nombre “Chris Nassetta”, incluyendo referencias a perfiles en plataformas como LinkedIn o Facebook. Estos resultados no deben interpretarse como validaciones automáticas del username exacto por parte de la herramienta, sino como resultados de apoyo basados en búsquedas documentales o en motores externos.

En **CheckUser**, la verificación no pudo completarse debido a una limitación operativa del servicio asociada al sistema CAPTCHA. Como consecuencia, no se obtuvo un resultado usable ni positivo ni negativo para esta herramienta.

Interpretación técnica

Desde un punto de vista metodológico, el resultado de **WhatsMyName** debe considerarse **negativo** para la validación automática del username **chrisnassetta**, ya que la herramienta no confirmó coincidencias en su tabla principal. La presencia de resultados inferiores relacionados con el nombre de la persona resulta útil como apoyo manual, pero no equivale a una confirmación técnica de reutilización del username por parte del motor principal de la herramienta.

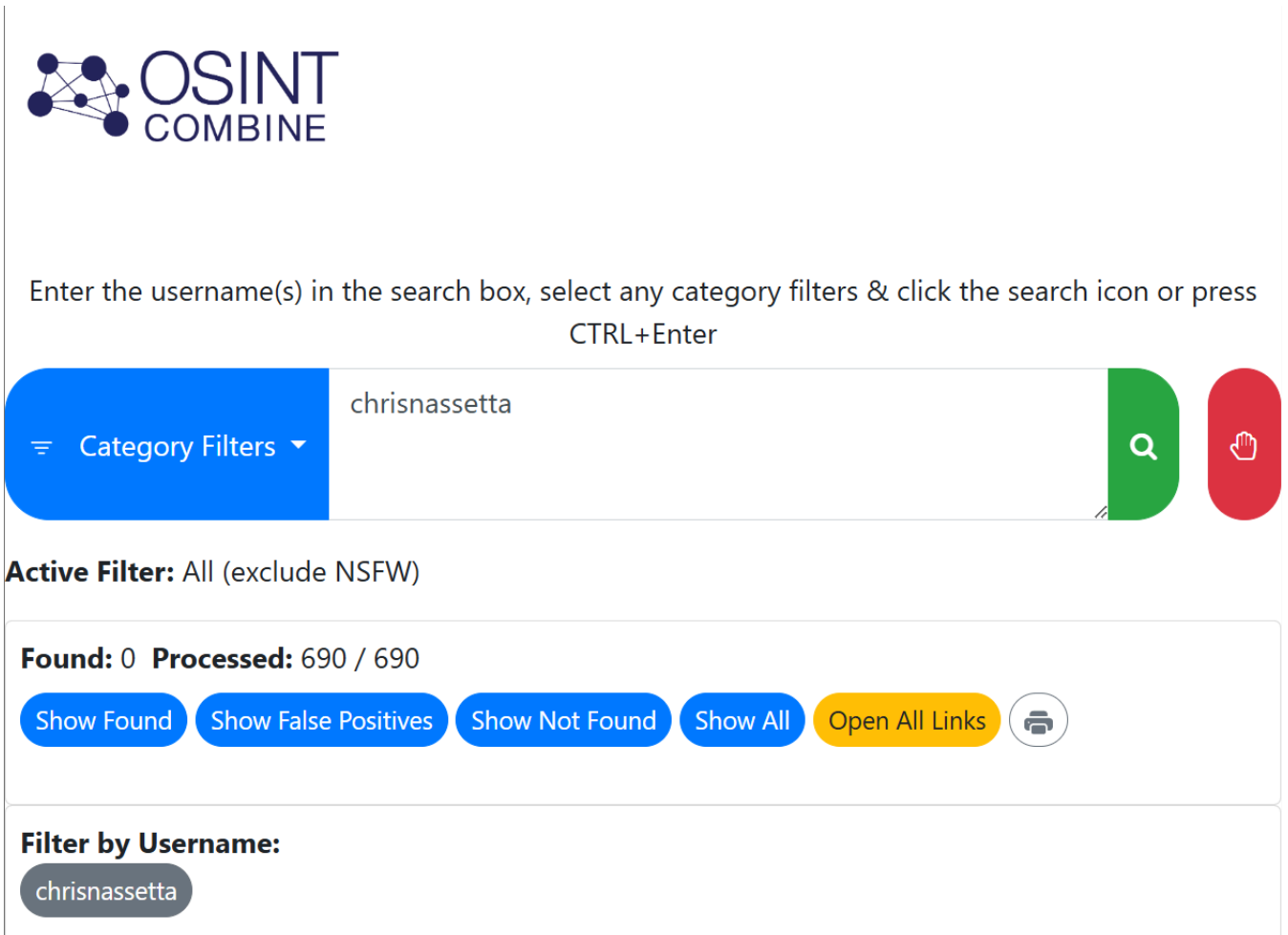
En el caso de **CheckUser**, la ausencia de resultado no se debe interpretar como inexistencia de perfiles o de exposición pública, sino como una **limitación operativa de acceso a la fuente**, provocada por las medidas

anti-bot del servicio. Este tipo de restricción es habitual en entornos OSINT y debe documentarse como parte del proceso, ya que afecta a la reproducibilidad práctica del análisis.

Interpretación global

Esta subfase permitió complementar el análisis de presencia digital iniciado anteriormente con Sherlock. En este caso, **WhatsMyName** no confirmó coincidencias automáticas para el username analizado, mientras que **CheckUser** no pudo utilizarse de forma efectiva por bloqueo del sistema CAPTCHA. El resultado conjunto muestra que no todas las herramientas ofrecen la misma cobertura ni el mismo nivel de accesibilidad operativa, por lo que los hallazgos deben valorarse en conjunto y siempre diferenciando entre resultados confirmados, resultados auxiliares y limitaciones técnicas de la fuente.

Evidencia





Enter the username(s) in the search box, select any category filters & click the search icon or press CTRL+Enter

 Category Filters ▾

chrisnassetta

Active Filter: All (exclude NSFW)

Found: 0 **Processed:** 690 / 690

[Show Found](#) [Show False Positives](#) [Show Not Found](#) [Show All](#) [Open All Links](#) 

Filter by Username:

[chrisnassetta](#)


CheckUser
[Buy Esim
Data](#)
[Social media
tools](#)
[Trademark
availability search](#)

Check Your Desired Usernames Across 70+ Popular Social Network Sites

Verification expired. Check the checkbox again.



I'm not a robot



reCAPTCHA
Privacy - Terms

Results:

Anexos generados

- [WhatsMyName Web.pdf](#) si lo conservas como evidencia exportada o captura documental
- No se generó anexo técnico útil de CheckUser debido a la limitación operativa del servicio

OSRFramework

Se realizó una comprobación adicional del identificador **chrisnassetta** mediante **OSRFramework** ([searchfy](#)) para contrastar su posible presencia en otras plataformas. La herramienta lanzó búsquedas sobre varios módulos, entre ellos **Github**, **Instagram** y **KeyServerUbuntu**, pero devolvió un resultado negativo: **"No data found..."**. Este hallazgo se interpreta como ausencia de coincidencias en los módulos

consultados por la herramienta durante la ejecución, sin que ello contradiga otros resultados obtenidos con fuentes distintas.

Evidencia:

```

OSINT Framework

Coded with ♥ by Yaiza Rubio & Félix Brezo

-- In 'alias_generator', '--common-words' adds words like 'xxx', 'real'... --

Searchfy | Copyright (C) Yaiza Rubio & Félix Brezo (i3visio) 2014-2021

This program comes with ABSOLUTELY NO WARRANTY. This is free software, and you
are welcome to redistribute it under certain conditions. For additional info,
visit <https://www.gnu.org/licenses/agpl-3.0.txt>.

2026-03-08 11:31:42.597771      Starting search in different platform(s) ... Relax!

    Press <Ctrl + C> to stop ...

    [*] Launching search using the Github module ...
    [*] Launching search using the Instagram module ...
    [*] Launching search using the KeyServerUbuntu module ...

2026-03-08 11:31:44.724623      Results obtained:

+-----+
| No data found ... |
+-----+

2026-03-08 11:31:44.724807      You can find all the information collected in the following files:
    ./profiles.csv

2026-03-08 11:31:44.724847      Finishing execution ...

Total time used:      0:00:02.127076
Average seconds/query: 2.127076 seconds

Did something go wrong? Is a platform reporting false positives? Do you need to
integrate a new one and you don't know how to start? Then, you can always place
an issue in the Github project:
    https://github.com/i3visio/osrframework/issues
Note that otherwise, we won't know about it!

```

Anexo asociado:

- 09_osint/osrframework_chrisnassetta_raw.txt

Conclusión

La práctica permitió completar de forma estructurada el reconocimiento sobre el scope *.hilton.com, abarcando las fases de footprinting, fingerprinting, análisis de vulnerabilidades y OSINT. A lo largo del proceso se identificaron subdominios activos, tecnologías expuestas, servicios accesibles, mecanismos de protección, posibles candidatos a subdomain takeover y la postura de seguridad del dominio principal en materia de TLS y autenticación de correo.

Además, la fase OSINT permitió localizar empleados relevantes, verificar la exposición pública de un correo corporativo y extraer metadatos de documentación pública asociada a Hilton. En conjunto, el trabajo proporcionó una visión amplia y reproducible de la superficie expuesta del objetivo, con hallazgos útiles tanto desde la perspectiva técnica como desde el análisis de información pública.